VULNERABLE MACHINE DEPLOYMENT & PRACTICAL PENETRATION TESTING

PHASE 2 — INTERNSHIP PROJECT REPORT

A REPORT ON

VULNERABILITY ASSESSMENT AND PENETRATION TESTING (VAPT) OF METASPLOITABLE 2

Submitted To: IqraSec Academy

Submitted By: Kaustubh Ashish Bangar

Cybersecurity Intern

Tools and Technologies Used

Kali Linux

Oracle VirtualBox

Metasploitable 2

Nmap

Netcat

NFS Utilities

Command-Line Security Tools

Project Type: Practical Cybersecurity Lab Assessment

Target Machine: Metasploitable 2

Assessment Environment: Isolated Virtual Lab

1. Project Overview and Objective

1.1 Project Overview

The project titled **"Vulnerable Machine Deployment and Practical Penetration Testing"** focuses on understanding and performing practical Vulnerability Assessment and Penetration Testing (VAPT) in a controlled virtual lab environment. The project involves deploying a vulnerable target machine using Oracle VirtualBox and conducting security testing from Kali Linux to identify potential weaknesses in the target system.

For this assessment, **Metasploitable 2** was selected as the target machine. It is an intentionally vulnerable Linux system designed for cybersecurity education and practical penetration-testing exercises. The lab environment was configured to allow communication between Kali Linux and Metasploitable 2 so that network discovery, service identification, enumeration, and controlled vulnerability validation could be performed.

The assessment included checking network connectivity, identifying open ports and running services using Nmap, examining selected services, and validating security weaknesses through practical tests. The findings were documented using terminal outputs and screenshots as evidence. Particular attention was given to an exposed bindshell service and the accessibility of the target's NFS-exported filesystem. All testing was conducted within the designated virtual lab environment.

1.2 Project Objectives

The main objectives of this project are:

1. **Lab Deployment:** Set up Kali Linux and Metasploitable 2 in Oracle VirtualBox for practical security testing.
2. **Network Configuration:** Configure and verify communication between the attacker and target virtual machines.
3. **Reconnaissance:** Identify the target machine and determine its reachable network services.

4. **Port and Service Scanning:** Use Nmap to discover open ports and identify the services and versions exposed by the target.
5. **Service Enumeration:** Examine selected services, including FTP, SMB, HTTP, NFS, and other accessible network services.
6. **Vulnerability Validation:** Perform controlled tests to confirm security weaknesses supported by practical evidence.
7. **Controlled Exploitation:** Demonstrate the impact of confirmed weaknesses within the authorized lab environment.
8. **Evidence Collection:** Record commands, terminal outputs, and screenshots to support the assessment findings.
9. **Risk Assessment:** Explain the potential security impact and assign appropriate severity levels to validated findings.
10. **Remediation:** Recommend security measures to reduce the identified risks and improve the target system's security.
11. **Learning and Documentation:** Develop practical skills in network security assessment, penetration-testing methodology, evidence collection, and technical reporting.

1.3 Project Scope

The assessment is limited to the Metasploitable 2 virtual machine deployed for this internship exercise. Testing includes network reconnaissance, port scanning, service enumeration, and controlled validation of accessible services. Exploitation activities are restricted to the intentionally vulnerable target within the isolated lab environment.

The purpose of the project is educational: to understand how exposed services and insecure configurations can affect system security and how appropriate remediation can reduce those risks. The results and conclusions are based on the tests performed and the evidence collected during the assessment.

2. Lab Setup and Network Configuration

2.1 Lab Environment Setup

The practical penetration-testing environment was established using Oracle VirtualBox to run two virtual machines: Kali Linux and Metasploitable 2. Kali Linux was used as the testing machine to perform reconnaissance, port scanning, service enumeration, and vulnerability validation. Metasploitable 2 was deployed as the target machine because it contains intentionally vulnerable services designed for cybersecurity training and penetration-testing practice.

Both virtual machines were configured to communicate within a controlled virtual network. This setup allowed security testing to be performed against the target without intentionally exposing the vulnerable machine to the public internet. The environment provided a practical platform for understanding network communication, identifying exposed services, validating security weaknesses, and collecting evidence for the assessment report.

2.2 Hardware and Software Requirements

The following hardware and software components were used to establish the virtual lab environment.

Component	**Description**
Host Operating System	Microsoft Windows
Virtualization Software	Oracle VirtualBox
Testing Machine	Kali Linux
Target Machine	Metasploitable 2
Network Environment	Virtual network configured in VirtualBox
Port Scanning Tool	Nmap
Connectivity Testing Tool	Ping
Service Testing Tool	Netcat
Additional Utilities	cURL and NFS utilities

2.3 Network Configuration

The Kali Linux and Metasploitable 2 virtual machines were configured in a virtual lab environment to enable communication between the testing machine and the target. During the assessment, the target machine was assigned the IP address **192.168.56.103**.

The network connection was verified by sending ICMP echo requests from Kali Linux to the target. A successful response indicated that the target was reachable from the testing machine. The HTTP service was also checked using cURL, which returned an HTTP 200 response, confirming that the target's web server was accessible.

The following IP address was used during the main assessment:

Device	**IP Address**	**Role**
Kali Linux	192.168.56.101*	Testing machine
Metasploitable 2	192.168.56.103	Target machine

Verify the Kali Linux IP address against your final lab configuration before submitting the report.

2.4 Network Connectivity Verification

Network connectivity was tested before starting the vulnerability assessment. The target's IP address was checked using the `ping` command from Kali Linux.

Command used:

```
ping -c 4 192.168.56.103
```

The target's HTTP service was then checked using the following command:

```
curl -I --connect-timeout 5 http://192.168.56.103/
```

The HTTP request returned a successful response with status code **200 OK**, indicating that the web server was responding to requests from the testing machine.

These preliminary tests confirmed that the target was reachable and that its web service was accessible, allowing the subsequent reconnaissance and enumeration activities to proceed.

2.5 Lab Safety and Isolation

The assessment was performed in a virtual lab environment for educational and training purposes. Since Metasploitable 2 contains intentionally vulnerable services, the target should remain isolated from untrusted networks.

The virtual network should be configured to restrict access to the intended lab machines. Bridged networking should be avoided unless specifically required and safely controlled. Testing should remain limited to the authorized Metasploitable 2 target.

This controlled environment supports safe experimentation, reproducible testing, and the collection of evidence without intentionally targeting unrelated systems.

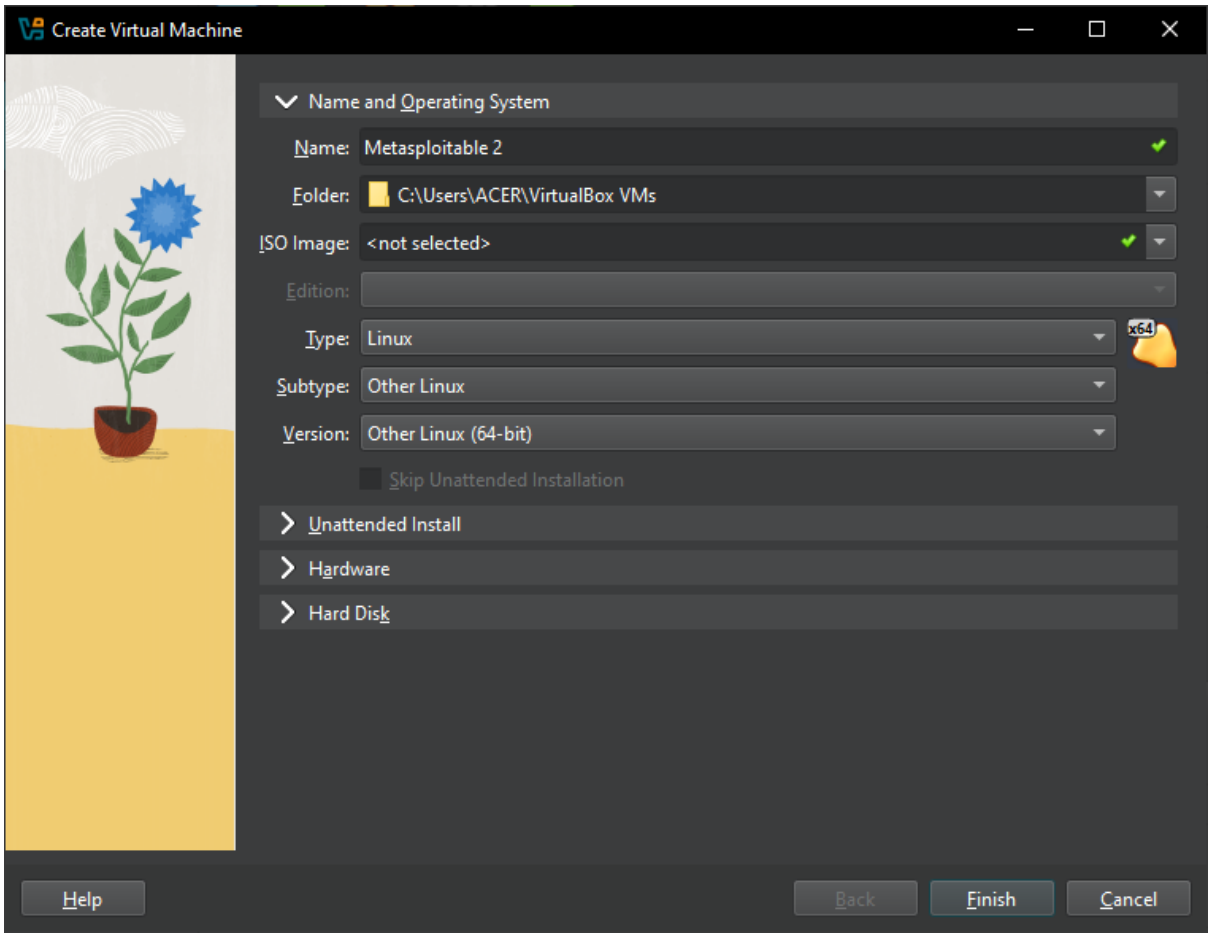


Fig : Metasploitable 2 Lab Setup



Fig : Kali Linux Lab Successfully Installed (Desktop)

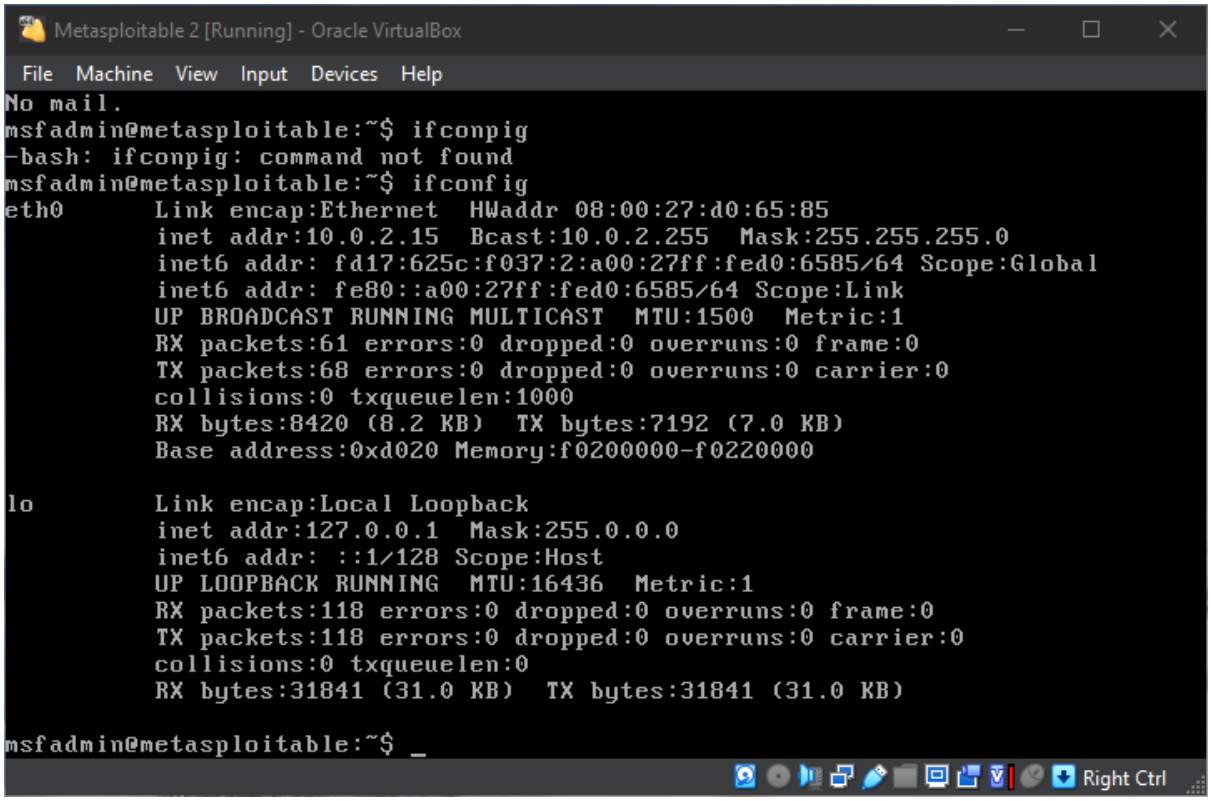


Fig : Metasploitable 2 Lab Installed Successfully

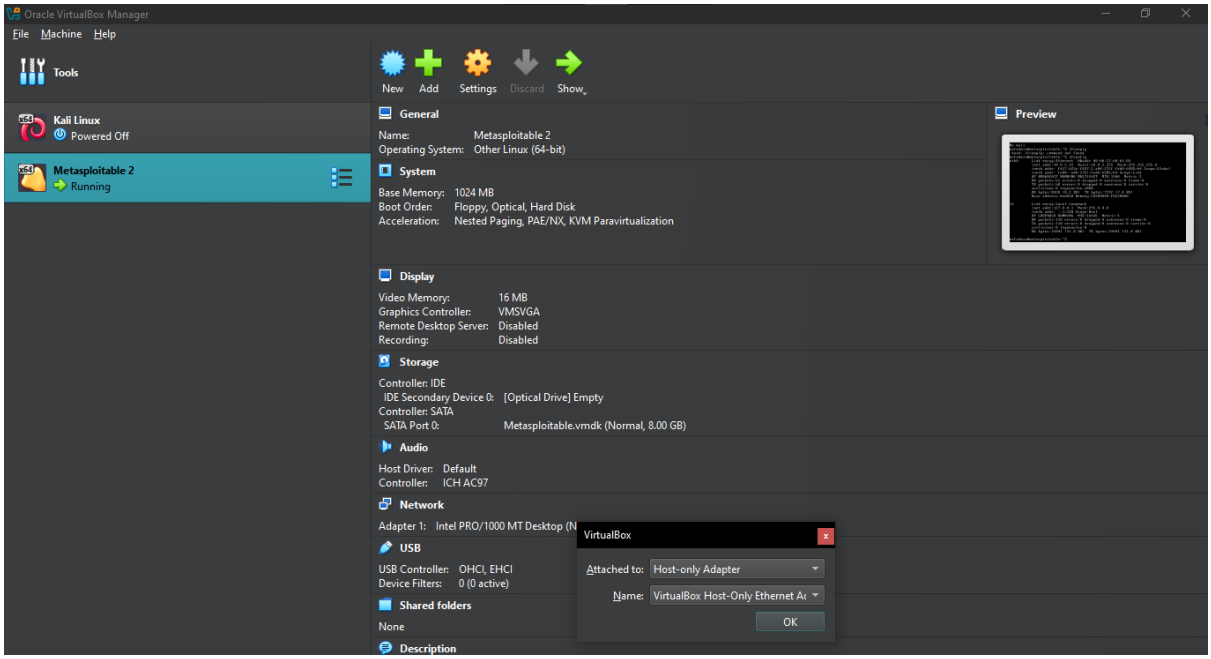


Fig : Metasploitable 2 Network Setting (Host-only Adapter)

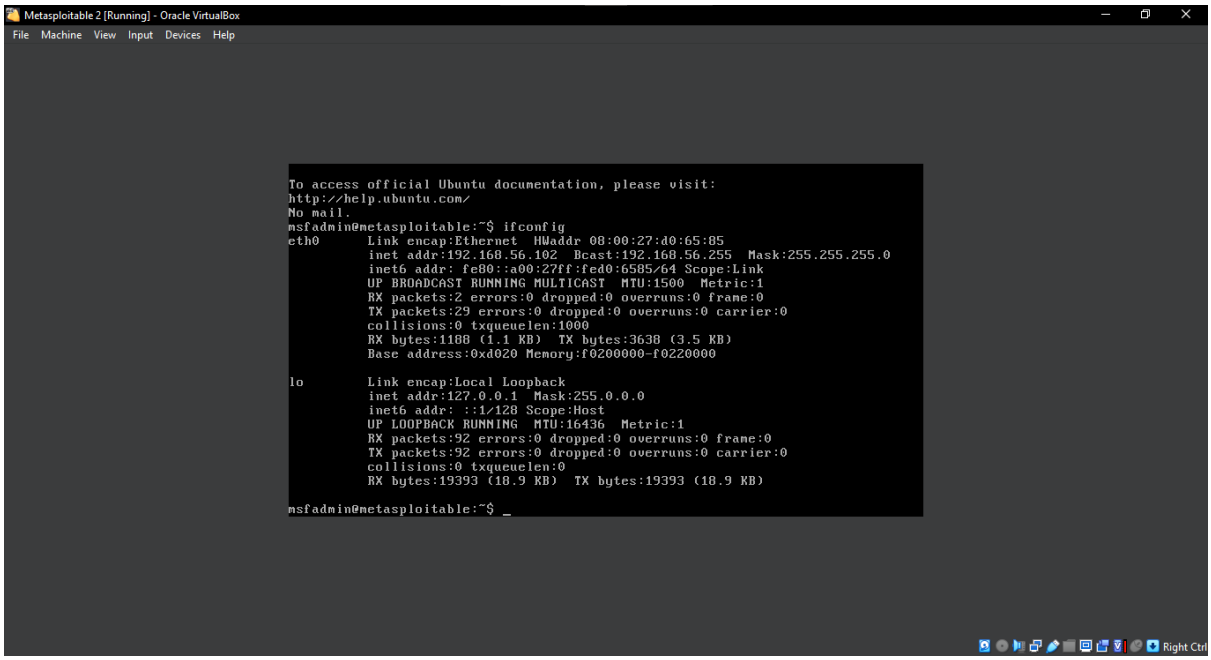


Fig : Metasploitable 2 ifconfig (IP Address)

3. Target Machine Details

3.1 Introduction to the Target Machine

The target machine is a fundamental component of a Vulnerability Assessment and Penetration Testing (VAPT) exercise. It is the system against which security tests are performed to identify exposed services, insecure configurations, outdated software, and potential vulnerabilities. A proper understanding of the target's operating environment, network accessibility, and available services is necessary before conducting detailed security testing.

For this project, Metasploitable 2 was selected as the target system. It is an intentionally vulnerable Linux virtual machine developed for cybersecurity education, penetration-testing practice, and security research in controlled environments. Unlike a normally secured production server, Metasploitable 2 includes multiple services and configurations that allow students to understand how security weaknesses can develop and how they can be detected and validated.

The target was deployed using Oracle VirtualBox and accessed from a separate Kali Linux virtual machine. Kali Linux served as the testing platform, while Metasploitable 2 acted as the target. This arrangement provided a practical environment for performing network discovery, port scanning, service enumeration, vulnerability validation, and controlled exploitation.

During the main assessment, the target was identified at IP address **192.168.56.103**. Connectivity tests and an HTTP request confirmed that the machine was reachable from the testing environment. Nmap service-version detection was subsequently used to identify the network services exposed by the target.

3.2 Overview of Metasploitable 2

Metasploitable 2 is a deliberately vulnerable virtual machine commonly used to learn the fundamentals of penetration testing. It provides an environment in which security professionals and students can investigate weaknesses without intentionally targeting real production systems.

The machine exposes a variety of network services, including file transfer, remote administration, web hosting, database access, file sharing, and other application services. These services demonstrate how a system's attack surface increases when multiple network-accessible components are enabled.

An attack surface refers to all the points through which an external or internal user could interact with a system. Each open network port may provide access to a service, but an open port alone does not prove that a vulnerability exists. The service must be examined to determine whether it exposes sensitive information, permits unauthorized access, uses insecure configurations, or contains exploitable weaknesses.

Metasploitable 2 is useful because it enables students to study these concepts through practical exercises. In this project, the target's accessible services were identified and selected services were examined to determine whether their configurations introduced security risks.

3.3 Target System Architecture and Working Environment

The practical environment consisted of two virtual machines running through Oracle VirtualBox.

Kali Linux — Testing Machine

Kali Linux was used to conduct the assessment. It provides security-testing utilities that support network reconnaissance, port scanning, service identification, connectivity testing, and evidence collection. Tools such as Nmap, Netcat, cURL, and NFS utilities were used during different stages of the practical work.

Metasploitable 2 — Target Machine

Metasploitable 2 hosted the services under examination. The assessment focused on identifying which ports were accessible, determining the services associated with those ports, and investigating selected services for security weaknesses.

Virtual Network — Communication Layer

The virtual network enabled communication between the testing and target machines. IP addressing allowed the testing machine to direct requests to the target. Network connectivity was checked before service-level testing began.

The general testing process was:

1. Start the Kali Linux and Metasploitable 2 virtual machines.
2. Verify the target's IP address and network reachability.
3. Perform port scanning to identify accessible TCP ports.
4. Use service-version detection to identify exposed services.
5. Enumerate selected services to understand their accessibility and configuration.
6. Validate suspected weaknesses using controlled tests.
7. Record the results and prepare evidence-based findings.

This architecture provided a structured environment for carrying out the assessment and documenting its results.

3.4 Target Identification and IP Address

An IP address identifies a device or network interface for communication over an IP network. During penetration testing, identifying the correct target address is essential because all subsequent scanning and validation activities depend on directing requests to the intended system.

The target used for the main assessment was identified as **192.168.56.103**. This address was used for the primary Nmap service-version scan and for validating the exposed bindshell service.

The address belongs to the private IPv4 range 192.168.0.0/16, which is reserved for private network use. Private addresses are commonly used in internal networks and virtual lab environments. However, using a private address does not automatically guarantee that a system is isolated or secure. The actual level of isolation depends on the network configuration, routing, firewall rules, and connectivity to other networks.

The target's reachability was checked using the `ping` command. The web service was also tested using cURL, which returned an HTTP 200 response. These tests confirmed network and application-level accessibility.

3.5 Operating System and Web Server Identification

Operating-system and service identification help an assessor understand the technologies running on a target. This information supports risk prioritization and helps determine which services require further investigation.

During the assessment, the HTTP response headers disclosed **Apache HTTP Server 2.2.8 (Ubuntu)** and **PHP 5.2.4**. These values were observed through the target's web service response and are recorded as the versions reported by the service.

Apache HTTP Server is software that processes HTTP requests and delivers web content to clients. PHP is a server-side scripting language commonly used to generate dynamic web pages and process application requests.

Older software versions may lack security fixes available in later releases. However, a version banner alone does not prove that a specific vulnerability is present or exploitable. Accurate vulnerability identification requires additional validation, including confirmation of the installed version, relevant configuration, and applicability of the suspected weakness.

The observed web server information therefore served as an initial indicator for further investigation rather than conclusive proof of a particular web vulnerability.

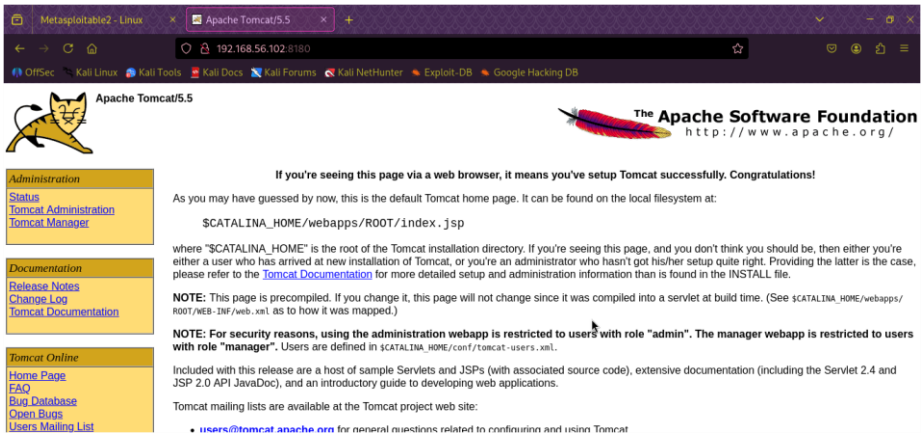


Fig : HTTP response showing Apache Information



Fig : HTTP response showing PHP Information

3.6 Open Ports and Network Services

A network port is a logical communication endpoint used by applications and services. TCP ports allow client applications to establish connections with services listening on a target system.

Nmap was used to identify open TCP ports and gather information about the services associated with them. The scan identified multiple accessible services, including FTP, SSH, Telnet, SMTP, DNS, HTTP, SMB, NFS, MySQL, PostgreSQL, VNC, and other network services.

The presence of numerous network-accessible services increases the number of components that must be secured and maintained. Each service may have its own authentication requirements, software dependencies, configuration options, and access controls.

The significance of an open port depends on the service behind it, the information or functionality it exposes, and the controls protecting it. A service may be legitimately open but still be vulnerable because of weak authentication, excessive permissions, outdated software, or an insecure configuration.

The initial scan therefore provided a foundation for selecting services for deeper examination. The results were interpreted together with service enumeration and practical validation rather than treating every open port as a confirmed vulnerability.

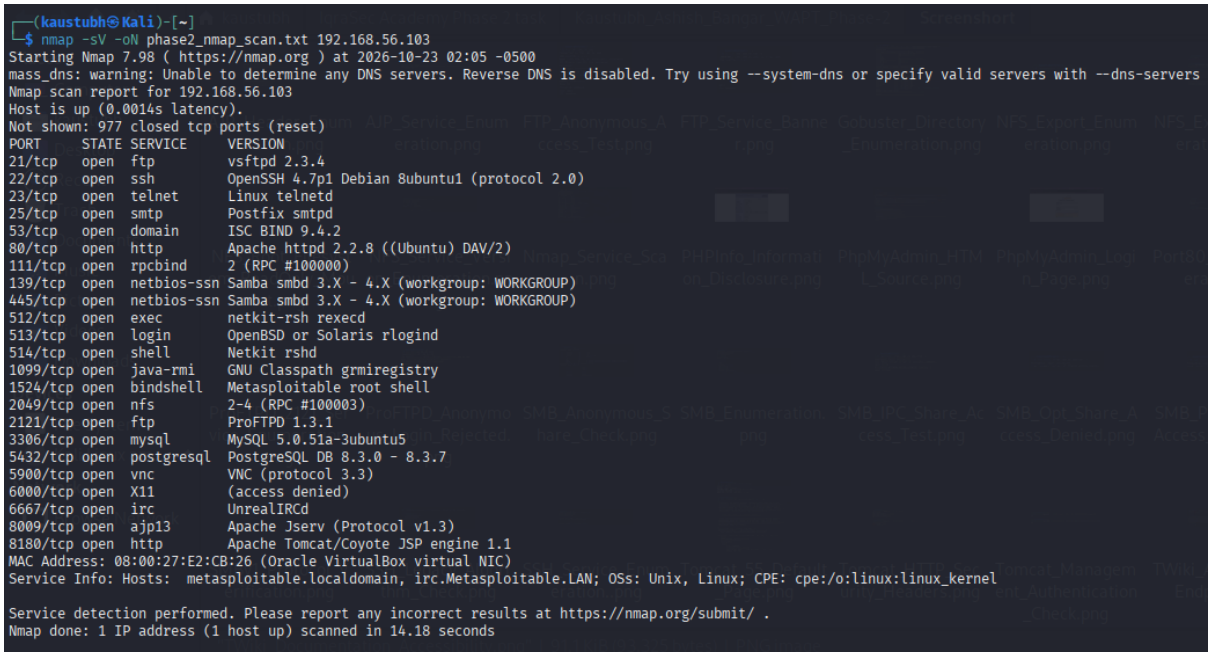


Fig : Nmap service-version scan

3.7 Important Services Observed During the Assessment

The following table summarizes selected services identified during the primary Nmap scan.

Port	Service	Observed Information	Security Relevance
21/tcp	FTP	vsftpd 2.3.4	Check authentication, anonymous access, and file permissions.
22/tcp	SSH	OpenSSH 4.7p1	Review authentication controls and software support.
23/tcp	Telnet	Telnet service detected	Telnet does not encrypt session traffic by default.
25/tcp	SMTP	Postfix	Review mail-service configuration and access controls.
53/tcp	DNS	BIND 9.4.2	Review DNS configuration and information exposure.
80/tcp	HTTP	Apache 2.2.8 (Ubuntu)	Examine web configuration, application exposure, and access controls.

139/tcp	NetBIOS/SMB	Samba service	Review file-sharing access and legacy protocol support.
445/tcp	SMB	Samba service	Examine share permissions and authentication requirements.
111/tcp	RPC	rpcbind	Review exposed RPC services and network restrictions.
1524/tcp	Bindshell	TCP service accepted a connection	Investigate unauthorized shell access; root access was confirmed in the lab.
2049/tcp	NFS	Network File System	Review exported directories and access restrictions.
3306/tcp	MySQL	MySQL 5.0.51a	Review network exposure, authentication, and database permissions.
5432/tcp	PostgreSQL	PostgreSQL 8.3.x range reported	Review database access restrictions and authentication.
5900/tcp	VNC	VNC service detected	Review remote-desktop authentication and network exposure.
6667/tcp	IRC	UnrealIRCd	Verify the running version and assess applicable security issues.
8009/tcp	AJP	AJP service detected	Review connector exposure and access restrictions.
8180/tcp	HTTP application service	Tomcat/Coyote detected	Review administrative interfaces and authentication controls.

Note: This table contains selected services from the observed scan. The version strings are scan results and should not be treated as proof of a vulnerability without further validation.

3.8 Bindshell Service and Security Significance

One of the most significant findings during the assessment involved TCP port 1524. A bindshell is a service that listens on a network port and provides command-shell access to a connecting client. If such a service permits unauthenticated access, it may allow a remote user to execute commands without passing through normal authentication controls.

During the practical test, a Netcat connection was established to the target's TCP port 1524. The `id` command returned the following result:

```
uid=0(root) gid=0(root) groups=0(root)
```

On Linux systems, UID 0 represents the root account, which normally has extensive administrative privileges. The output therefore confirmed that the connected shell provided root-level access in the lab environment.

This result demonstrates a critical security weakness because an unauthenticated network connection that provides a privileged shell can permit unauthorized command execution and compromise of the target system. In a real environment, the impact could include access to sensitive files, changes to system configuration, disruption of services, and further compromise of the host.

The evidence confirms root-level shell access through the tested service on the lab target. The finding should be reported as a confirmed security issue, with its final severity determined according to the assessment rubric and the exposure of the service.

3.9 NFS Service and Filesystem Access

The Network File System (NFS) protocol allows systems to share directories and files over a network. It is commonly used in Unix-like environments to provide centralized file access. However, incorrect export settings can expose sensitive filesystem content to unauthorized clients.

During the assessment, the NFS service on the target was examined. The export enumeration result indicated that the root filesystem was exported with a broad client specification. A

subsequent mount allowed the exported filesystem to be accessed for reading, and the hostname file identified the system as `metasploitable`.

Access to a broadly exported filesystem may expose configuration files, system information, and other data that should be restricted. The actual impact depends on the server's export options, client restrictions, file permissions, and the contents accessible to the connecting user.

The mount used during the practical test included the client-side `ro` option. This option restricted the mounted filesystem to read-only access from the testing machine. It does not establish that the NFS server itself enforced read-only access. Therefore, the confirmed result is that the exported filesystem was accessible for reading; server-side write access was not established by this test.

The finding demonstrates the importance of restricting NFS exports to authorized clients and applying appropriate permissions and root-squashing controls.

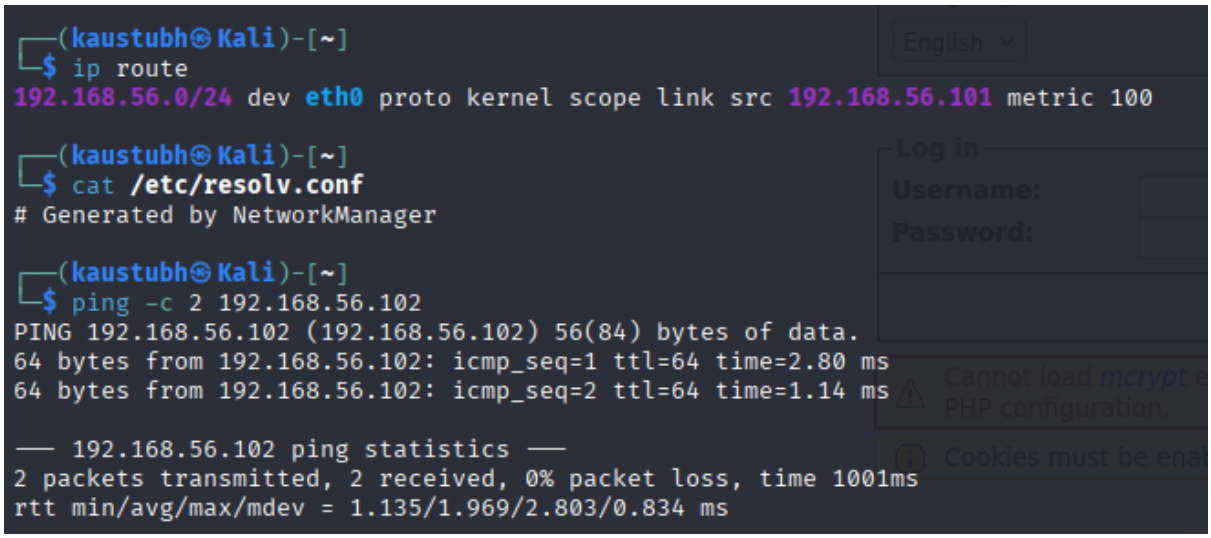


Fig: NFS export enumeration

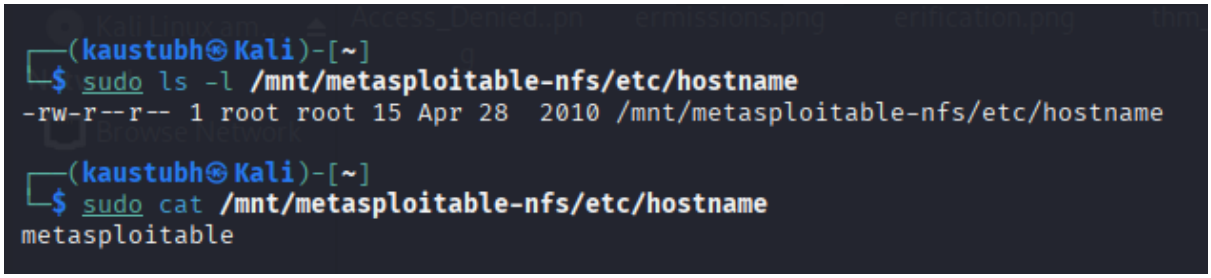


Fig : NFS filesystem access or hostname output

3.10 Importance of Target Identification in VAPT

Target identification is an essential stage of a penetration test because the assessor must understand the system being examined before attempting to validate vulnerabilities. Accurate identification helps prevent testing the wrong host and supports the reproducibility of the assessment.

Service identification also helps determine which tests are relevant. For example, an exposed file-sharing service requires different validation steps from a web server or database service. A systematic approach reduces unnecessary testing and allows the assessor to prioritize findings based on their demonstrated impact.

In this project, the target's IP address, HTTP response, and Nmap service-version scan provided the initial technical profile. Follow-up tests against TCP port 1524 and the NFS service produced additional evidence about the target's security posture.

The results demonstrate how reconnaissance and service enumeration support later vulnerability validation. They also highlight why a professional VAPT report must distinguish between an observed service, a suspected weakness, and a vulnerability confirmed through practical testing.

3.11 Summary of Target Machine Assessment

Metasploitable 2 provided a practical environment for examining the security implications of exposed network services and insecure configurations. The initial scan identified numerous open TCP ports and several services requiring further investigation. The web server also disclosed its software banner, providing information for subsequent assessment.

Further testing confirmed root-level shell access through TCP port 1524. Separate NFS testing confirmed read access to the exported filesystem. These results provided evidence of significant security weaknesses within the deliberately vulnerable target.

Overall, the target identification and service enumeration stages established the technical foundation for the remaining assessment. The findings were documented to support risk analysis, remediation recommendations, and the final conclusions of the VAPT project.

4. Scope and Methodology

4.1 Introduction

The scope and methodology define the boundaries, objectives, and systematic procedures followed during a Vulnerability Assessment and Penetration Testing (VAPT) exercise. The scope identifies the systems, services, and activities included in the assessment, while the methodology describes the sequence of steps used to identify, examine, validate, and document potential security weaknesses.

A structured methodology is essential because penetration testing involves multiple stages, from initial reconnaissance to vulnerability validation and risk assessment. Following a systematic process helps ensure that testing is organized, repeatable, and supported by technical evidence.

In this project, a controlled virtual laboratory was established using Oracle VirtualBox. Kali Linux was used as the testing machine, and Metasploitable 2 was used as the intentionally vulnerable target. The assessment focused on identifying exposed network services, examining selected service configurations, validating security weaknesses, and documenting the results for remediation.

All practical activities were intended to remain within the authorized training environment.

4.2 Scope of the Assessment

The scope defines the boundaries within which the security assessment was conducted. Clearly defining the scope helps prevent accidental testing of unrelated systems and ensures that the findings remain relevant to the assigned internship task.

4.2.1 In-Scope Systems

The following components were included in the assessment:

Component	Description
Testing machine	Kali Linux virtual machine
Target machine	Metasploitable 2 virtual machine
Target IP address	192.168.56.103 for the primary assessment
Virtualization platform	Oracle VirtualBox
Network reconnaissance	Connectivity testing and port scanning
Service identification	Detection of open ports and service versions
Service enumeration	Examination of selected accessible services
Vulnerability validation	Controlled testing of suspected weaknesses
Evidence collection	Terminal outputs, scan results, and screenshots
Risk assessment	Evaluation of the impact of confirmed findings
Remediation planning	Recommendations for correcting identified weaknesses

The assessment concentrated on services exposed by the Metasploitable 2 target. The primary service scan and bindshell validation used the target address `192.168.56.103`.

4.2.2 Out-of-Scope Activities

The following activities were excluded from the assessment:

1. Testing systems outside the designated lab environment.
2. Scanning public IP addresses or unrelated network devices.
3. Performing denial-of-service attacks or stress testing.

4. Testing real production servers or systems belonging to other individuals.
5. Attempting to access third-party accounts or confidential information.
6. Modifying or deleting data unnecessarily.
7. Performing persistence or maintaining unauthorized access beyond the controlled demonstration.
8. Testing destructive exploitation techniques that could damage the virtual machine or host system.

These restrictions helped maintain a controlled testing environment and kept the project focused on the assigned educational objectives.

4.3 Assessment Methodology

The assessment followed a structured, evidence-based methodology consisting of several phases. Each phase contributed to the identification and validation of security weaknesses.

4.3.1 Phase 1: Lab Preparation

The first phase involved preparing the virtual testing environment. Kali Linux was used as the testing platform, while Metasploitable 2 served as the target machine.

The virtual machines were started, and the target's network accessibility was checked before testing began. The purpose of this phase was to establish a functioning lab and ensure that commands could be directed to the intended target.

Activities performed:

- Starting the virtual machines.
- Checking the target's IP address.
- Verifying network connectivity.
- Confirming access to the target's web service.

4.3.2 Phase 2: Reconnaissance

Reconnaissance is the process of collecting initial information about a target system. In a network security assessment, this includes identifying the target's availability and determining which services may be accessible.

The target's reachability was checked using the `ping` command. An HTTP request was also sent using cURL to determine whether the web service was responding.

Example command:

```
ping -c 4 192.168.56.103
```

This command sends four ICMP echo requests to the target. Responses indicate that the target is reachable through the network path, provided ICMP traffic is permitted.

The web service was checked using:

```
curl -I --connect-timeout 5 http://192.168.56.103/
```

The HTTP response returned status code `200 OK`, confirming that the web server responded to the request.

4.3.3 Phase 3: Port Scanning and Service Detection

Port scanning identifies network ports that accept connections. Service detection attempts to determine which applications or services are associated with those ports.

Nmap was used to perform TCP service-version detection against the target.

Command used:

```
nmap -sV -oN phase2_nmap_scan.txt 192.168.56.103
```

The `-sV` option enables service-version detection. The `-oN` option saves the results in normal text format for review and documentation.

The scan identified multiple open ports associated with services such as FTP, SSH, Telnet, HTTP, SMB, NFS, database services, and remote-access services.

The results were used to select services for further examination. An open port was treated as evidence of service exposure, not as automatic proof of a vulnerability.

4.3.4 Phase 4: Service Enumeration

Service enumeration involves collecting additional information about services identified during scanning. Depending on the service, this may include examining access permissions, authentication requirements, exported resources, response headers, or publicly available service information.

Selected services on Metasploitable 2 were examined using appropriate command-line tools.

The FTP service was checked for anonymous access. SMB enumeration was used to examine visible shares and access restrictions. The HTTP service was inspected for response information and accessible resources. NFS enumeration was used to examine exported directories.

The objective of enumeration was to understand what an unauthenticated or ordinary network client could access and to identify configurations requiring further investigation.

4.3.5 Phase 5: Vulnerability Validation

Vulnerability validation determines whether a suspected security weakness is actually present. This phase is important because service banners and automated scan results can indicate potential risks without proving that a vulnerability is exploitable.

During the assessment, TCP port 1524 was tested using Netcat. The connection was successful, and the `id` command returned UID 0, confirming root-level shell access through the service.

The NFS service was also investigated. The exported filesystem was successfully mounted for read access, and the target's hostname file was read. This confirmed that filesystem content was accessible through the tested export.

The NFS mount used a client-side read-only option. Therefore, the test confirmed read access but did not establish whether the server permitted writes.

4.3.6 Phase 6: Evidence Collection

Evidence collection was performed to maintain a record of the practical assessment. Screenshots and command outputs were used to support observations and demonstrate the results of selected tests.

The evidence included:

- Network connectivity checks.
- Nmap service-version scan results.
- HTTP response information.
- Selected service enumeration results.
- The bindshell connection and root-identity output.
- NFS export and filesystem access results.

Evidence was intended to show the command or test performed and its corresponding output. Where screenshots came from different lab sessions or target IP addresses, they were to be identified separately to avoid misrepresenting the results.

4.3.7 Phase 7: Risk Assessment

Risk assessment evaluates the potential consequences of an identified weakness. Factors may include the level of access obtained, the sensitivity of accessible data, the need for authentication, the network exposure of the service, and the potential impact on confidentiality, integrity, and availability.

The confirmed root shell through TCP port 1524 represents a serious security issue because it demonstrates privileged command access without normal authentication. The NFS result demonstrates filesystem read access through an exported directory, although the extent of its impact depends on the accessible contents and server-side configuration.

Severity levels should be assigned according to the evidence, the assessment rubric, and the actual exposure of each weakness. A service version alone should not be assigned a confirmed vulnerability rating without supporting validation.

4.3.8 Phase 8: Remediation Recommendations

The final phase involves identifying measures that can reduce or eliminate the risks associated with confirmed findings.

Recommendations include disabling unnecessary services, restricting access to required services, applying security updates, reviewing file-sharing permissions, removing insecure configurations, and strengthening authentication and network access controls.

For the exposed bindshell, the recommended action is to disable the service and verify that the port is no longer accessible. For NFS, the export configuration should be reviewed, access restricted to authorized clients, and appropriate server-side permissions and root-squashing controls applied.

Remediation should be followed by additional testing to confirm that the identified weaknesses have been addressed.

4.4 Tools Used in the Assessment

Tool	**Purpose**
Oracle VirtualBox	Running the Kali Linux and Metasploitable 2 virtual machines
Kali Linux	Security-testing operating system
Nmap	Discovering open ports and identifying services
Ping	Checking network reachability
cURL	Testing HTTP responses and inspecting web-server headers
Netcat	Testing TCP connectivity and validating the exposed bindshell
NFS utilities	Enumerating exports and checking filesystem access
Terminal screenshots	Recording practical evidence

4.5 Methodology Summary

The assessment followed a systematic process beginning with lab preparation and target reachability checks. Network scanning was then performed to identify exposed ports and services. Selected services were examined through enumeration, and suspected weaknesses were subjected to controlled validation.

The practical evidence confirmed root-level shell access through TCP port 1524 and read access to the exported NFS filesystem. These observations provided a basis for discussing the target's security weaknesses, evaluating their potential impact, and recommending remediation measures.

The methodology emphasized controlled testing, evidence-based conclusions, and clear differentiation between observed services, suspected risks, and confirmed security weaknesses. This approach supports a reproducible assessment and helps ensure that the final report accurately represents the work performed.

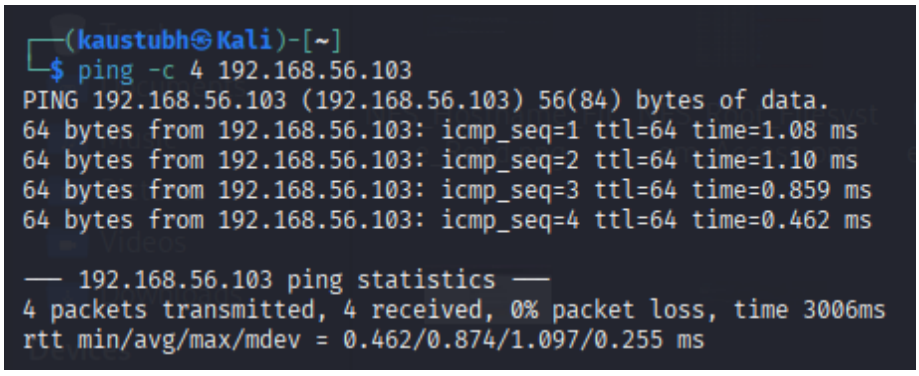


Fig : Successful ping to 192.168.56.103

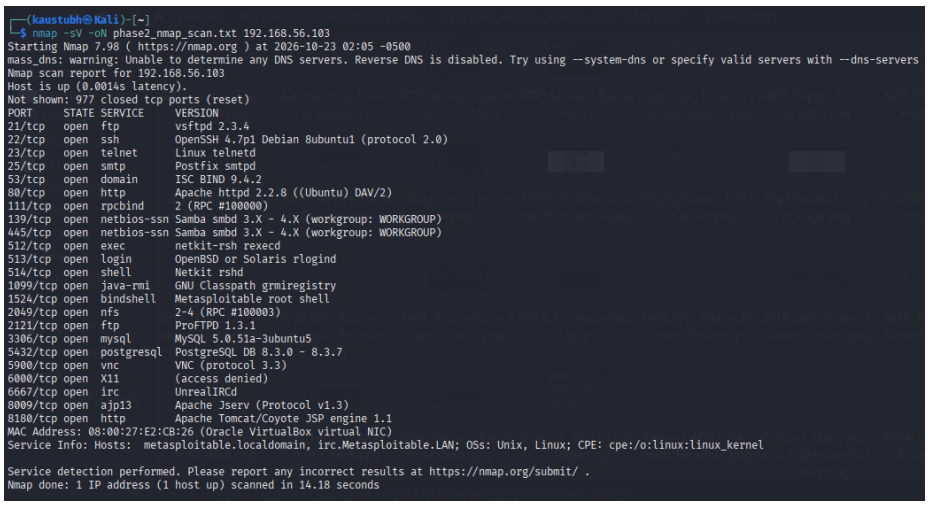


Fig : Nmap service-version scan

5. Reconnaissance and Enumeration Results

5.1 Introduction

Reconnaissance and enumeration are important stages of Vulnerability Assessment and Penetration Testing (VAPT). They help an assessor understand the target environment, identify accessible network services, and collect information that can guide further security testing.

Reconnaissance focuses on gathering initial information about a target, including its network availability and externally observable characteristics. Enumeration goes further by examining discovered services to determine what information, resources, or functionality they expose to a connecting client.

In this project, reconnaissance and enumeration were performed against the Metasploitable 2 virtual machine using Kali Linux. The primary target address was `192.168.56.103`. The assessment used network connectivity checks, Nmap service-version detection, HTTP response inspection, and selected service-specific tests.

The purpose of these activities was to establish the target's observable network profile, identify services requiring further investigation, and collect evidence to support subsequent vulnerability validation.

5.2 Reconnaissance

5.2.1 Objective of Reconnaissance

The main objective of reconnaissance was to verify the target's network accessibility and collect initial technical information before performing detailed service enumeration.

Reconnaissance helps an assessor answer several important questions:

- Is the target reachable from the testing machine?
- Which network services appear to be accessible?
- Does the target expose information about its software?
- Which services should be investigated further?
- What evidence should be collected for the assessment report?

The information gathered during this stage provides the foundation for the subsequent enumeration and vulnerability-validation phases.

5.2.2 Target Reachability Test

The target's availability was checked from Kali Linux using the `ping` command.

Command:

```
ping -c 4 192.168.56.103
```

The command sends four ICMP echo requests to the target and displays the responses received.

Observation: The target responded to the connectivity test, confirming that it was reachable from the testing machine at the time of testing.

Result: Network communication between Kali Linux and the target was established sufficiently to proceed with the planned service checks.

A successful ping does not prove that every network service is accessible or that the target is secure. It confirms only that ICMP communication was successful during the test.

5.2.3 Web Server Reconnaissance

The target's HTTP service was examined using cURL to determine whether the web server was responding and to inspect its response headers.

Command:

```
curl -I --connect-timeout 5 http://192.168.56.103/
```

The `-I` option requests HTTP headers without downloading the complete response body. The `--connect-timeout 5` option limits the time allowed to establish the connection.

Observed results:

- HTTP status: `200 OK`
- Web server: Apache HTTP Server 2.2.8 (Ubuntu)
- PHP version information: PHP 5.2.4 was reported in the response information.

Result: The web server was accessible and disclosed software-version information.

Security significance: Software banners can help an assessor identify technologies that require further investigation. However, a disclosed version does not by itself establish that a specific vulnerability is present. Additional validation is required before reporting a version-related security issue as confirmed.

5.3 Port Scanning and Service Detection

5.3.1 Purpose of Port Scanning

Port scanning is used to identify network ports that accept connections on a target system. Each open port may correspond to a network service, such as a web server, database server, file-sharing service, or remote-access service.

Identifying these ports helps establish the target's network attack surface. The results can be used to prioritize services for further examination.

For this assessment, Nmap was used to perform TCP service-version detection.

5.3.2 Nmap Command Used

```
nmap -sV -oN phase2_nmap_scan.txt 192.168.56.103
```

The command uses the following options:

Option	Explanation
`nmap`	Starts the Nmap network scanning utility.
`-sV`	Attempts to identify the services and versions associated with discovered ports.
`-oN phase2_nmap_scan.txt`	Saves the results in normal text format.
`192.168.56.103`	Specifies the target IP address.

The saved output provides a record of the scan that can be reviewed during analysis and used as supporting evidence in the final report.

5.3.3 Observed Open Ports and Services

The primary Nmap scan identified the following open TCP ports and service information.

Port	Service	Observed Service Information
21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	Telnet	Telnet service detected
25/tcp	SMTP	Postfix
53/tcp	DNS	BIND 9.4.2
80/tcp	HTTP	Apache 2.2.8 (Ubuntu), DAV/2
111/tcp	RPC	rpcbind
139/tcp	SMB	Samba service detected
445/tcp	SMB	Samba service detected
512/tcp	Remote execution	rexec
513/tcp	Remote login	rlogin
514/tcp	Remote shell	rsh
1099/tcp	Java RMI	Java RMI registry
1524/tcp	Bindshell	TCP service accepted a connection
2049/tcp	NFS	Network File System
2121/tcp	FTP	ProFTPD 1.3.1
3306/tcp	MySQL	MySQL 5.0.51a

5432/tcp	PostgreSQL	PostgreSQL 8.3.0–8.3.7 range reported
5900/tcp	VNC	VNC 3.3
6000/tcp	X11	X Window System service
6667/tcp	IRC	UnrealIRCd
8009/tcp	AJP	Apache JServ Protocol service
8180/tcp	HTTP application service	Tomcat/Coyote

Total observed open TCP ports: 23.

These results show that multiple services were exposed through the target's network interface. The service names and versions represent Nmap's observations during the scan and should be treated as initial identification results rather than independent proof of vulnerabilities.

5.3.4 Analysis of Port-Scanning Results

The scan identified several categories of network services:

File transfer and sharing: FTP and NFS provide file-transfer or shared-filesystem functionality. SMB provides network file and resource sharing. These services require careful examination of authentication, permissions, and accessible resources.

Remote access and command execution: SSH, Telnet, rexec, rlogin, and rsh provide remote-access or remote-execution functionality. Their security depends on the protocols used, authentication requirements, configuration, and network exposure.

Web and application services: HTTP on port 80 and the application service on port 8180 provide web-based functionality. The AJP service on port 8009 may also provide communication between a web server and an application server.

Database services: MySQL and PostgreSQL were identified as accessible network services. Database exposure should be evaluated according to authentication requirements, network restrictions, and the sensitivity of accessible data.

Other services: DNS, SMTP, Java RMI, VNC, X11, and IRC were also detected. Each requires service-specific analysis to determine whether its configuration introduces a security risk.

The results were used to select services for further enumeration and validation. The presence of an open port alone was not considered sufficient evidence of a vulnerability.

5.4 Service Enumeration

Service enumeration involves interacting with discovered services to collect additional information about their behaviour, configuration, authentication requirements, and accessible resources.

The following services were examined during the practical assessment.

5.4.1 FTP Enumeration — Port 21

File Transfer Protocol (FTP) is used to transfer files between a client and a server. Traditional FTP does not encrypt credentials or transferred data by default, making secure configuration and appropriate network restrictions important.

During the earlier FTP test against the lab target, anonymous login was successful, but the directory listing was empty.

Observation: Anonymous FTP access was accepted during the test, but no files were listed in the accessible directory.

Security significance: Anonymous access may expose information or resources if the server permits access to sensitive files or allows unauthorized uploads. In this test, the empty directory listing limited the evidence of direct data exposure.

Result: Anonymous FTP authentication was confirmed in the earlier lab session. The accessible directory did not display files during that test.

Evidence note: Ensure that the screenshot identifies the correct target IP. If the result came from the earlier target address, report it as an observation from that earlier lab session.

5.4.2 FTP Enumeration — Port 2121

A second FTP service was identified on TCP port 2121. The observed service banner identified ProFTPD 1.3.1.

An anonymous login attempt was rejected with the response `530 Login incorrect`.

Observation: Anonymous FTP authentication was not accepted by the service during the test.

Security significance: The result demonstrates that anonymous access was not available through the attempted login. It does not establish whether authenticated access was secure or whether the service had other vulnerabilities.

Result: Anonymous login was rejected during the test.

5.4.3 SMB Enumeration — Ports 139 and 445

Server Message Block (SMB) is a network protocol used for file sharing and access to shared resources. SMB security depends on protocol configuration, authentication, share permissions, and restrictions on client access.

The SMB service was examined to identify visible shares and determine whether unauthenticated enumeration was possible.

The earlier lab test identified the following share names:

- `print$`
- `tmp`
- `opt`
- `IPC$`
- `ADMIN$`

The `tmp` share allowed directory listing during the test, while access to other examined shares was denied.

Observation: Some share information was accessible without successful authentication.

Security significance: Unnecessary anonymous enumeration can reveal information about the target's resources. The practical impact depends on what an unauthenticated user can read or modify.

Result: Share enumeration was possible, but the test did not establish unauthorized write access to the shares.

5.4.4 HTTP and WebDAV Enumeration — Port 80

The target's web service was examined to identify server information and available HTTP methods.

The server returned an HTTP `200 OK` response and disclosed Apache HTTP Server 2.2.8 (Ubuntu) and PHP 5.2.4 information.

The WebDAV endpoint was also examined. The earlier test observed support for WebDAV-related methods, including `PROPFIND`, `PROPPATCH`, `COPY`, `MOVE`, `LOCK`, and `UNLOCK`. A `PROPFIND` request returned HTTP status `207 Multi-Status`.

WebDAV extends HTTP to support remote management of web resources. Its security depends on authentication, authorization, method restrictions, and filesystem permissions.

Observation: WebDAV functionality was available, and the server responded to a resource-discovery request.

Security significance: Unnecessary WebDAV methods or weak access controls can increase the risk of unauthorized resource access or modification. However, the presence of these methods does not prove that unauthorized file modification is possible.

Result: WebDAV functionality was confirmed in the earlier lab test. Unauthorized file modification was not established.

5.4.5 NFS Enumeration — Port 2049

Network File System (NFS) allows remote systems to access shared directories. Incorrect export rules can expose filesystem content to clients that should not have access.

During an earlier lab session, NFS export enumeration reported the root filesystem as exported with a broad client specification. A subsequent mount allowed filesystem content to be read.

The hostname file returned the value `metasploitable`.

Observation: The exported filesystem was accessible for reading during the test.

Security significance: Broadly accessible filesystem exports can expose configuration information and other sensitive data. The actual impact depends on export settings, file permissions, client restrictions, and the contents exposed.

Result: Read access was demonstrated. The mount used a client-side read-only option, so server-side write access was not proven.

Important evidence limitation: The archived NFS screenshots show the earlier target address `192.168.56.102`, whereas the primary Nmap scan and bindshell validation used `192.168.56.103`. Keep the NFS results identified as earlier-session observations unless you have matching evidence from the current target address.

5.4.6 Tomcat and AJP Enumeration — Ports 8180 and 8009

The scan identified a Tomcat/Coyote application service on port 8180 and an AJP service on port 8009.

During the earlier web-enumeration tests, the Tomcat manager and host-manager paths returned HTTP `401 Unauthorized`, indicating that authentication was required for those requests.

Observation: The Tomcat service was accessible, while the tested manager paths required authentication.

Security significance: Administrative interfaces should be restricted to authorized users and, where appropriate, trusted network locations. An open AJP port also warrants configuration review, but its presence alone does not confirm that exploitation is possible.

Result: The service and authentication challenge were observed. Unauthorized administrative access was not demonstrated.

5.5 Summary of Reconnaissance and Enumeration Findings

The following table summarizes the main observations from reconnaissance and enumeration.

No.	Service or Activity	Observation	Status
1	Network reachability	Target `192.168.56.103` responded to connectivity testing	Confirmed
2	HTTP	HTTP `200 OK`; Apache/PHP information disclosed	Confirmed
3	TCP port scanning	23 open TCP ports observed	Confirmed
4	FTP on port 21	Anonymous login accepted in an earlier lab session	Confirmed for that session
5	FTP on port 2121	Anonymous login rejected	Confirmed for that session
6	SMB	Share names could be enumerated; `tmp` listing was accessible	Confirmed for that session
7	WebDAV	WebDAV methods and `PROPFIND` response observed	Confirmed for that session
8	NFS	Exported filesystem was accessible for reading in an earlier session	Confirmed for that session
9	TCP port 1524	Connection provided a root-level shell	Confirmed on `192.168.56.103`

10	Tomcat manager	Tested manager paths returned HTTP `401 Unauthorized`	Confirmed for that session

The status labels indicate whether the described observation was made during the relevant test. They do not mean that every service listed has a confirmed exploitable vulnerability.

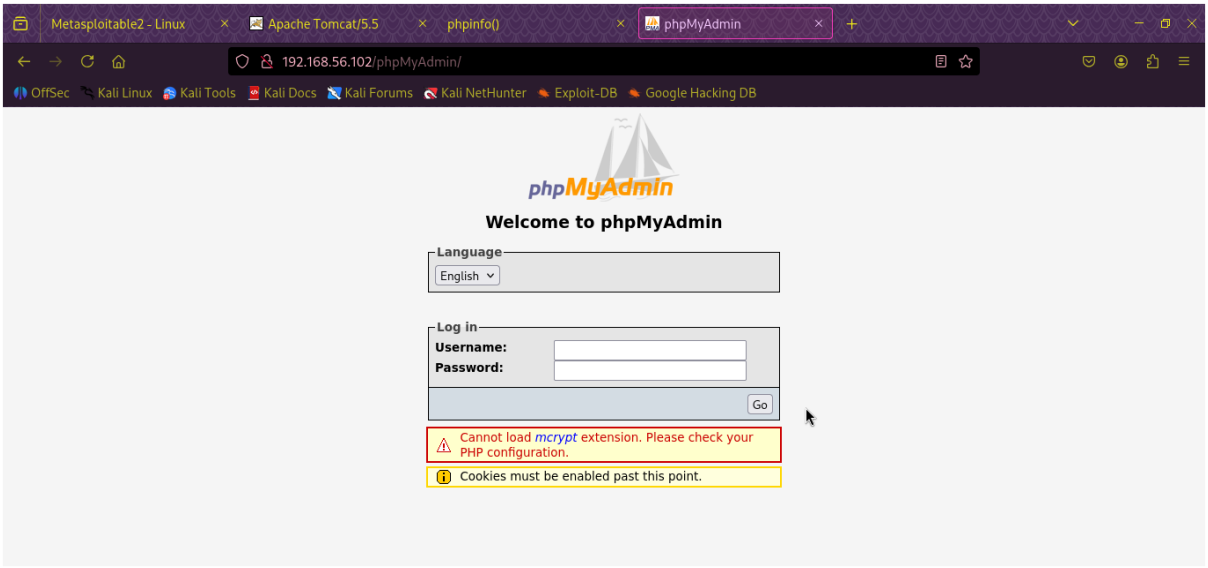


Fig : PhpMyAdmin Login Page



Fig : Check HTTP port 80

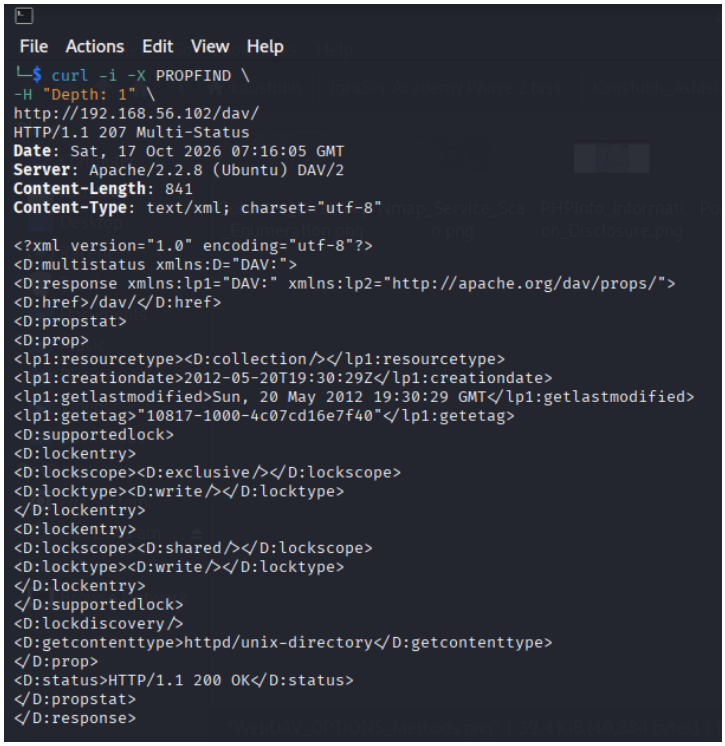


Fig : WebDAV PROPFIND Response

Interpretation: The server allows an unauthenticated `PROPFIND` request to retrieve metadata about `/dav/`. This confirms WebDAV functionality and metadata disclosure, but does not by itself prove unauthorized file access or modification.

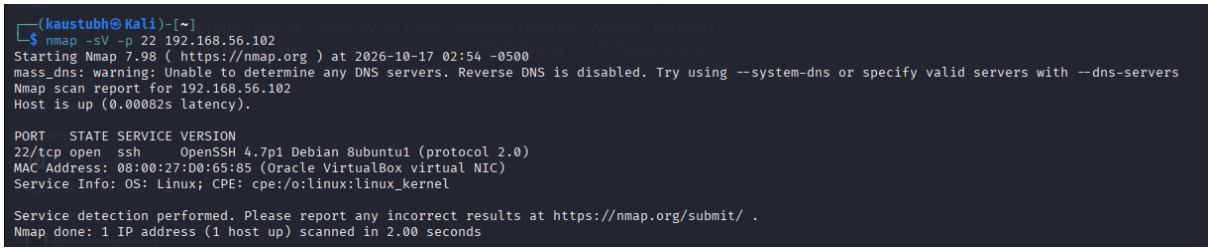


Fig: SSH Service Enumeration

Item	Result
Target	`192.168.56.102`
Port	`22/tcp`
Status	Open
Service	SSH
Reported version	OpenSSH `4.7p1 Debian 8ubuntu1`
Protocol	SSH 2.0

Status: Legacy algorithms observed; further configuration assessment required.

Recommendation: Upgrade the SSH server and configure modern, supported host-key algorithms.

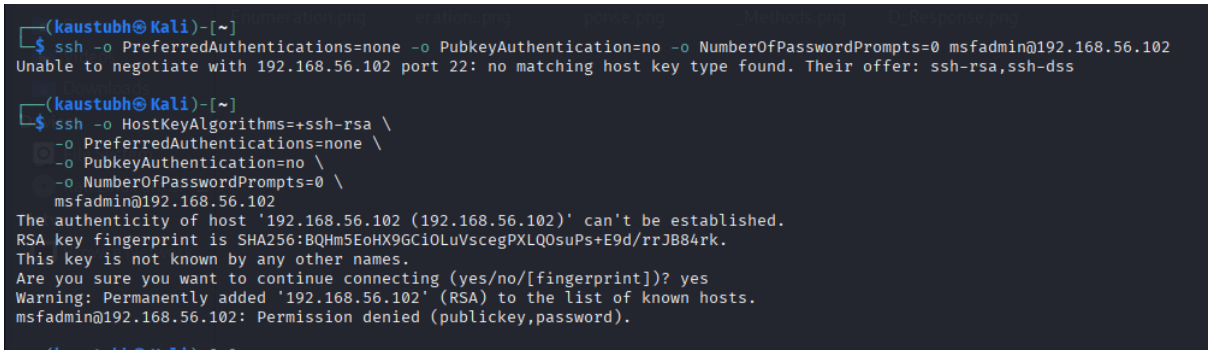


Fig: SSH Legacy Algorithm Check

This means:

- **SSH connectivity:** Confirmed.
- **Legacy host-key compatibility:** The connection progressed past the initial algorithm negotiation.
- **Host key:** Saved in Kali's `known_hosts` file.
- **Authentication:** Denied, as expected because we disabled authentication attempts in the command.
- **Successful SSH login:** Not achieved or tested.

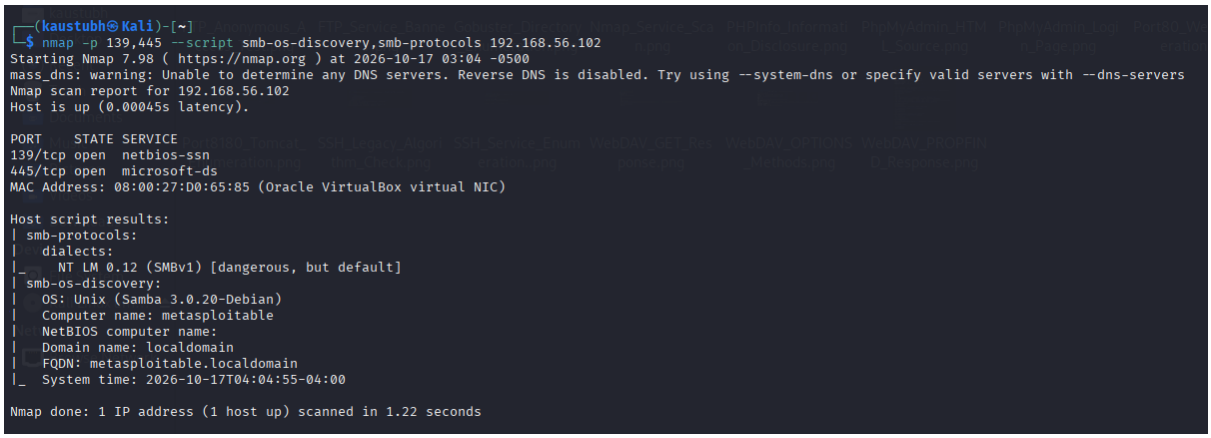


Fig: SMB Enumeration

Security concern: SMBv1 is an obsolete protocol with known security weaknesses. Its presence is a valid configuration concern, although the scan alone does not establish that this particular server is exploitable.

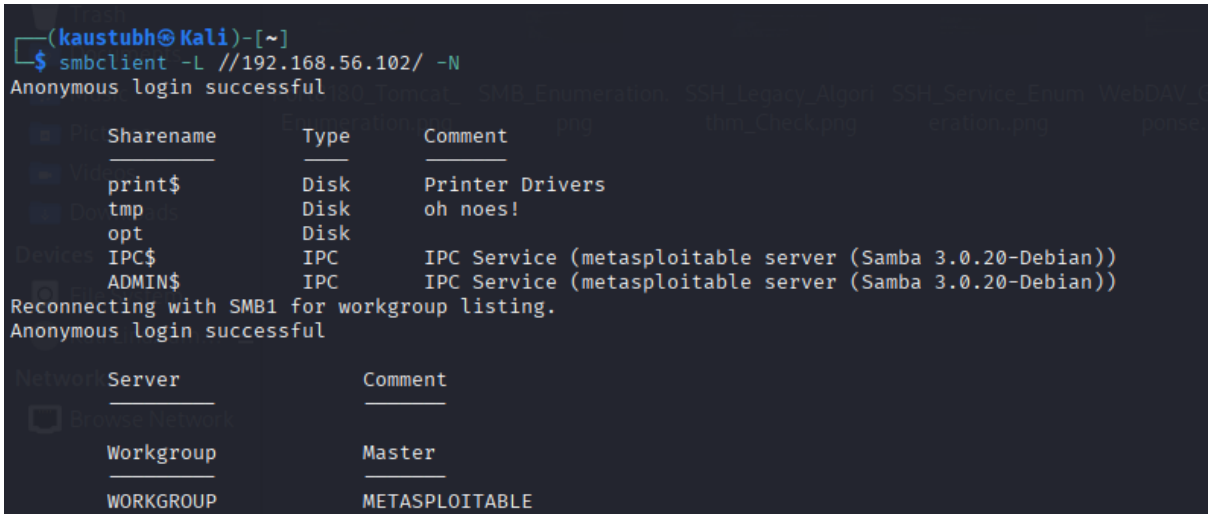


Fig: SMB Anonymous Share Check

Anonymous login successful and files listed: Unauthenticated access to those listed filenames is confirmed; assess whether the contents are sensitive before rating the finding.
Anonymous login successful but access denied to listing: The share is reachable, but listing permissions are restricted.
Login or connection rejected: Record the exact error.

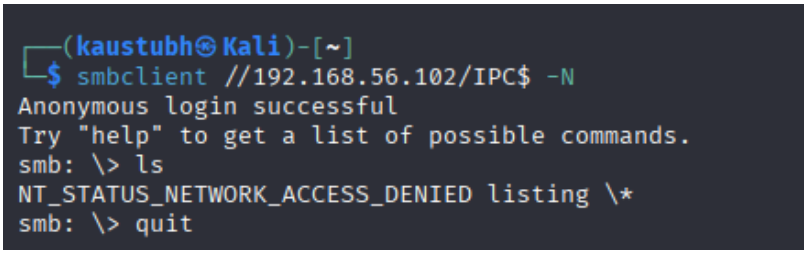


Fig: SMB IPC Share Access Test

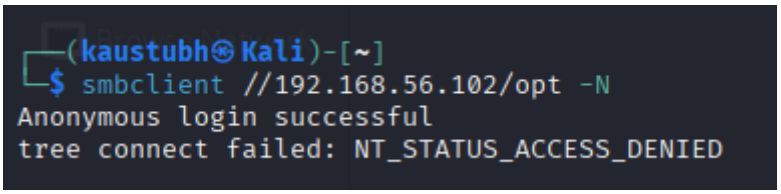


Fig: SMB Opt Share Access Denied

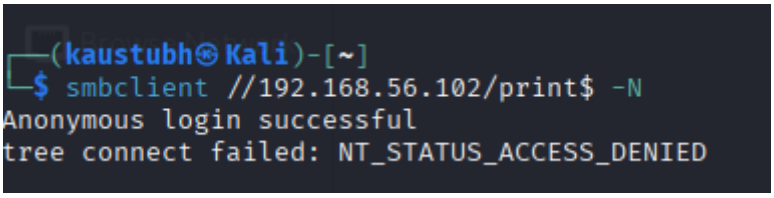


Fig : SMB Print Share Access Denied

Security observation: Anonymous SMB sessions are accepted, but access permissions differ between shares. The `tmp` share permits directory listing, whereas `opt` and `print$` deny access.

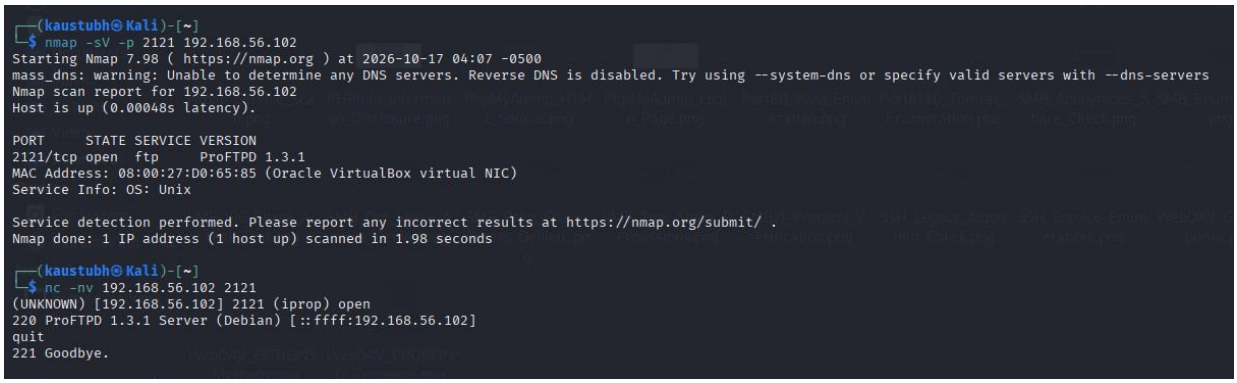


Fig: ProFTPD 2121 Service Enumeration

The target exposes an FTP service on TCP port 2121. Nmap identified the service as ProFTPD 1.3.1, and a direct connection confirmed the server banner.

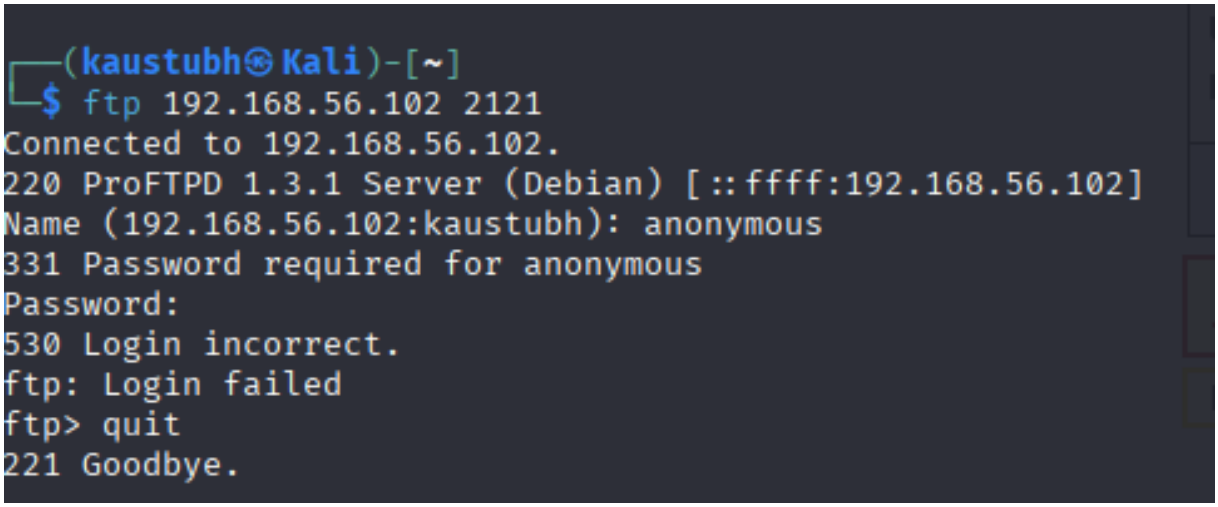


Fig: ProFTPD Anonymous Login Rejected

Observation: The target runs ProFTPD 1.3.1 on TCP port 2121. The server banner disclosed the product and version. An anonymous login attempt was rejected with `530 Login incorrect`.

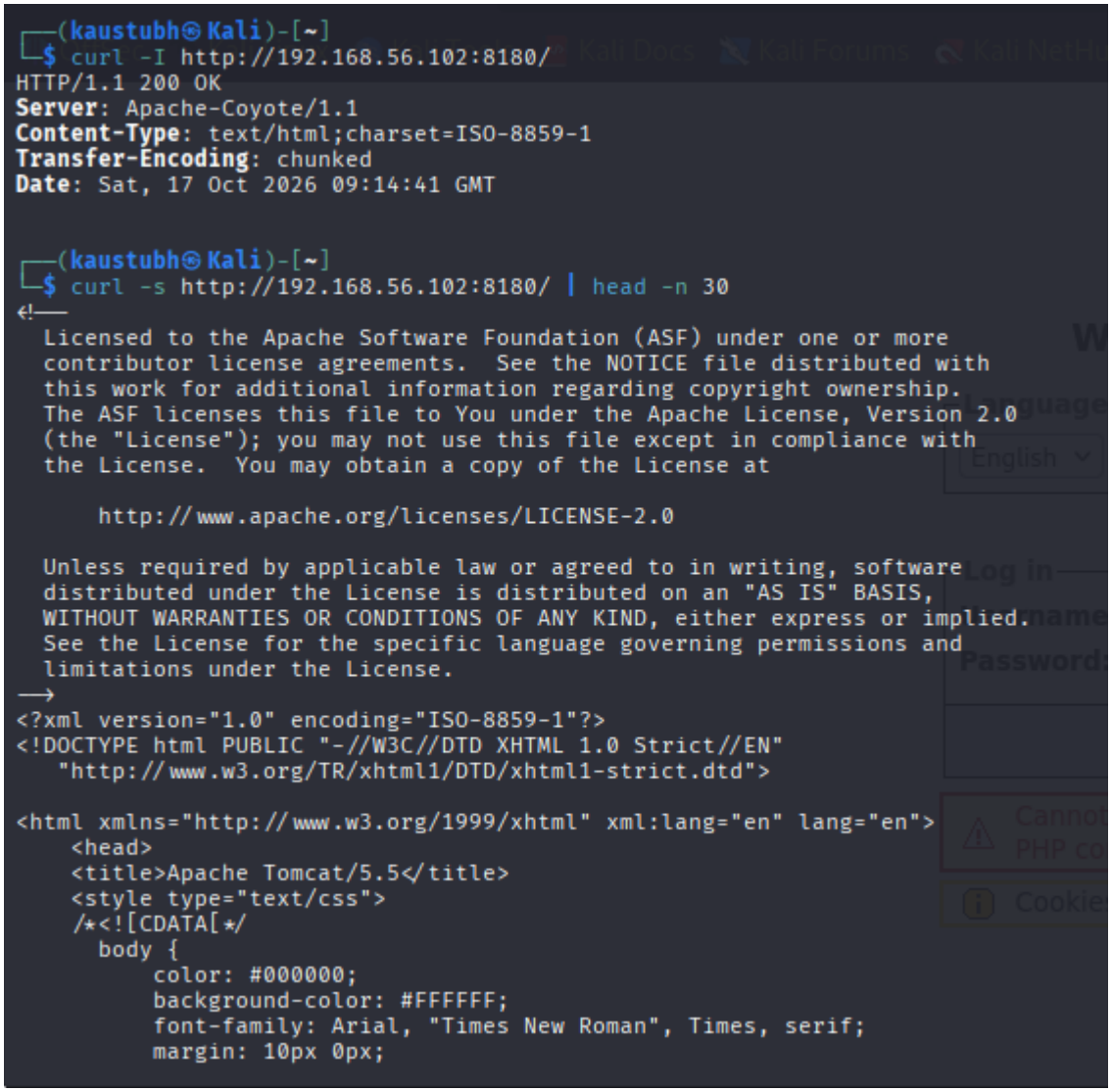


Fig: Tomcat 55 Default Page

Observation: The target serves an Apache Tomcat 5.5 default page over HTTP on port 8180.

Potential impact: Legacy software may contain known security vulnerabilities. The banner and default page alone do not establish that a specific vulnerability is exploitable.



Fig: Tomcat Management Authentication Check

Observation: Requests to the Tomcat Manager and Host Manager paths returned HTTP 401. This indicates that authentication is required for these endpoints.

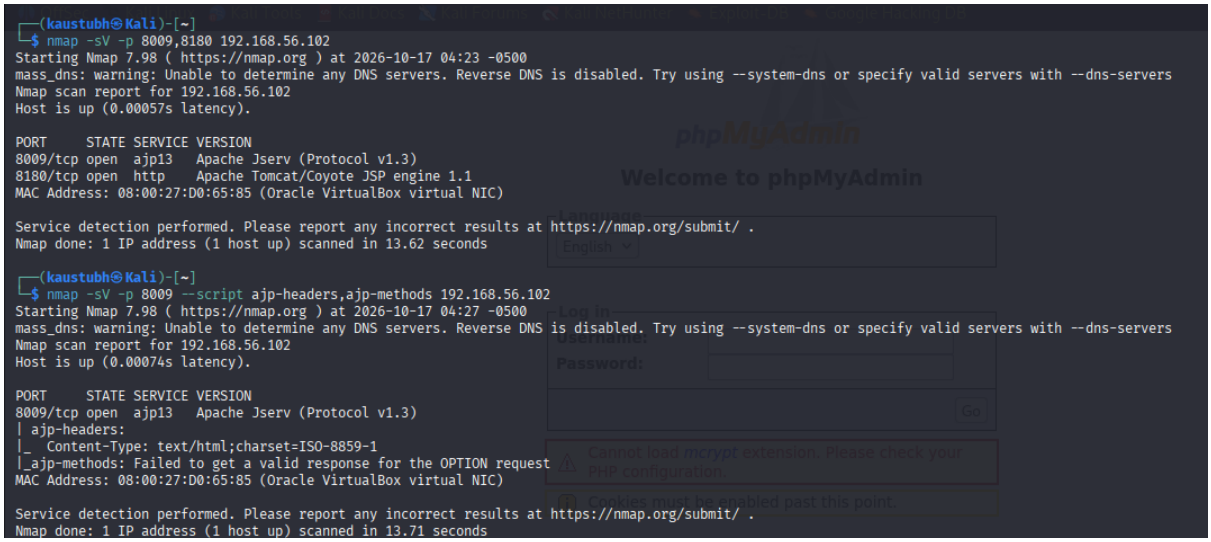


Fig: AJP Header Enumeration

Evidence: Nmap identified the service as open. The `ajp-headers` script returned an HTML content-type header.
Potential risk: An unnecessarily exposed or improperly configured AJP service may increase the attack surface.

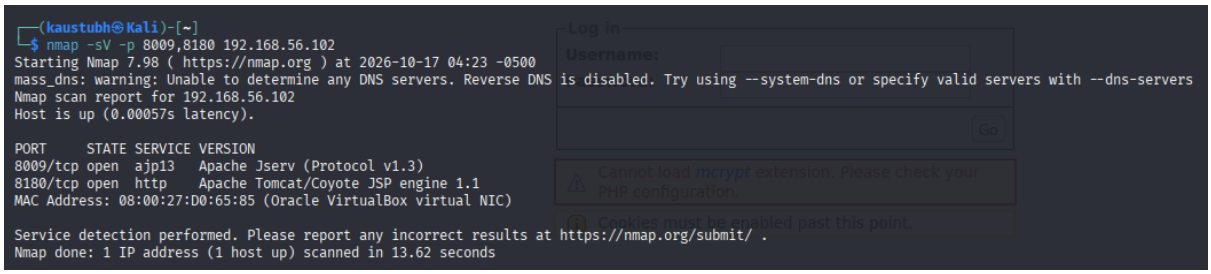


Fig: AJP Service Enumeration

Evidence: Nmap identified port 8009 as open and detected `ajp13`.
Potential impact: If the service is misconfigured or vulnerable, an exposed AJP interface may create additional attack paths.



Fig: Web Application Path Enumeration

Observation: All four paths returned HTTP 200 responses. These include an administration interface, a WebDAV directory, and two additional application paths.

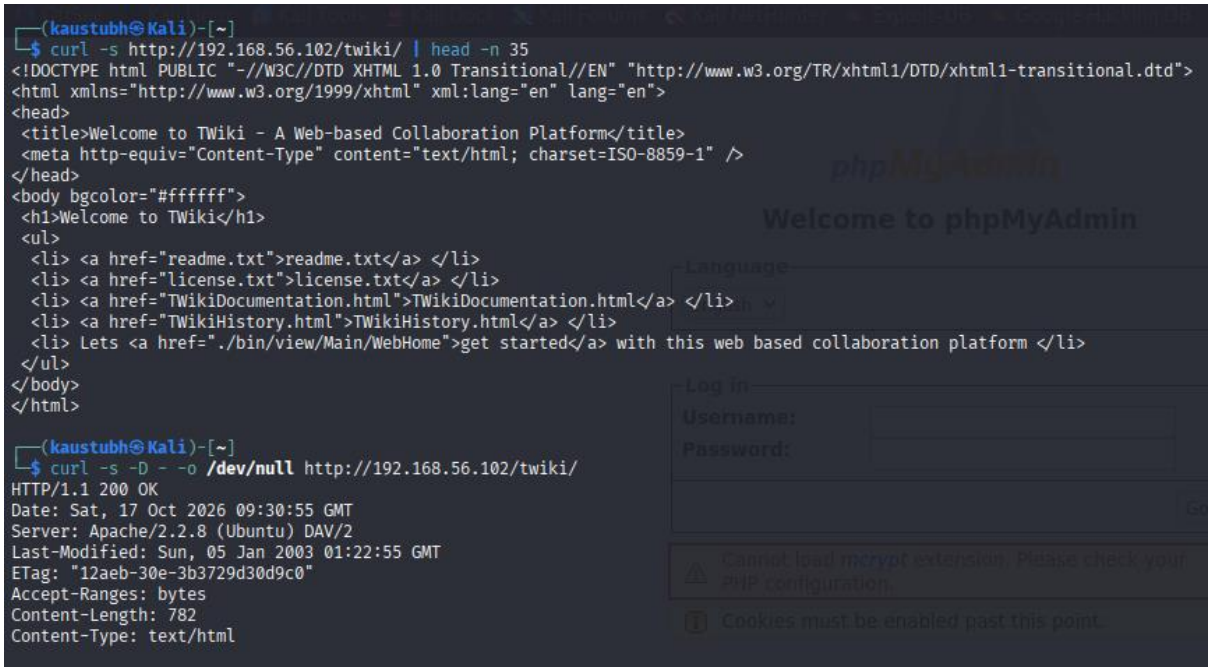


Fig: TWiki Application Enumeration

Potential Impact: Application and server information may help an attacker identify the technology stack and plan further reconnaissance. This evidence does not independently establish that the application is exploitable.

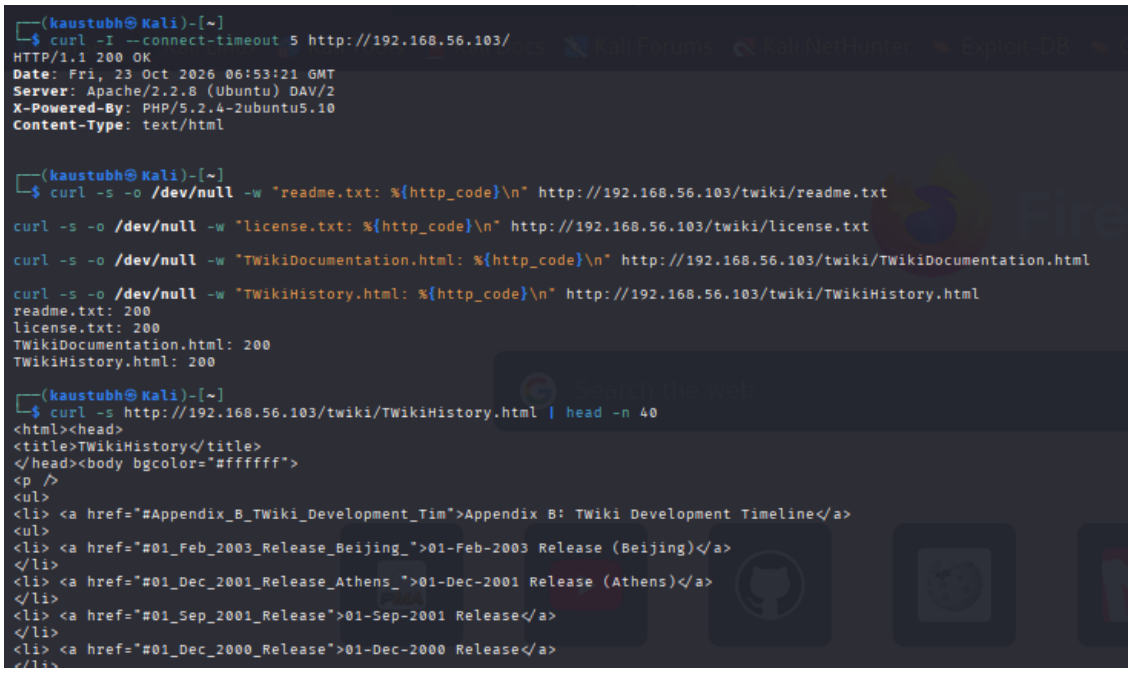


Fig: TWiki Documentation Accessibility

Evidence: All four resources returned HTTP 200. The history page contains a timeline of historical TWiki releases, including releases dating back to 1998.

6. Vulnerabilities Identified

6.1 Introduction

During the assessment of Metasploitable 2, several security weaknesses and potentially risky configurations were identified. Nmap was used to discover open ports and services, while additional tests were performed to examine service access and validate selected weaknesses.

6.2 Identified Vulnerabilities

ID	Vulnerability / Finding	Affected Service	Severity
VULN-01	Unauthenticated root-level shell access	TCP port 1524	Critical
VULN-02	Broad NFS filesystem exposure	TCP port 2049	High — preliminary
VULN-03	Anonymous FTP login permitted	TCP port 21	Low — preliminary
VULN-04	SMB share information exposure	TCP ports 139, 445	Low — preliminary
VULN-05	WebDAV functionality exposed	TCP port 80	Requires further validation
VULN-06	Older software versions disclosed	Multiple services	Informational

Severity ratings are preliminary and depend on the demonstrated impact and assessment criteria.

6.3 VULN-01: Unauthenticated Root-Level Shell

Description: TCP port 1524 accepted a connection and provided a command shell without normal authentication.

Validation: Netcat was used to connect to the target at `192.168.56.103`. The `id` command returned:

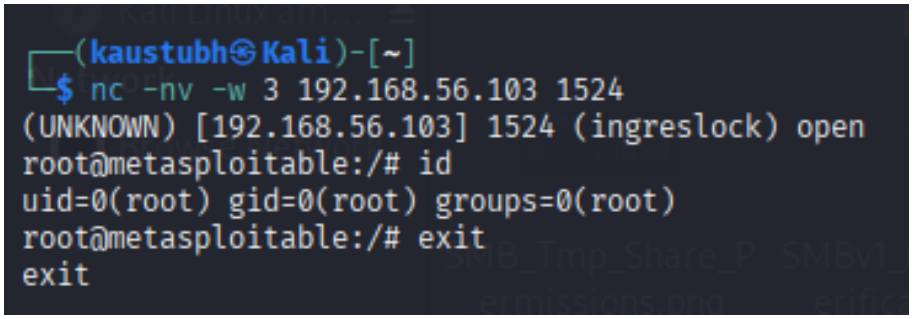
```
uid=0(root) gid=0(root) groups=0(root)
```

Impact: An unauthorized user could obtain administrative access, read sensitive files, modify system configurations, or disrupt services.

Severity: Critical.

Recommendation: Disable the exposed service, restrict unnecessary network access, and verify that port 1524 is closed.

Evidence:



6.4 VULN-02: NFS Filesystem Exposure

Description: During an earlier lab session, NFS enumeration revealed a broadly accessible filesystem export.

Validation: The exported filesystem was mounted for read access, and the hostname file was successfully read.

Impact: Exposed files may disclose system configuration and other sensitive information.

Severity: High — preliminary.

Recommendation: Restrict NFS exports to authorized clients, remove unnecessary exports, apply least-privilege permissions, and configure appropriate root-squashing controls.

Evidence:

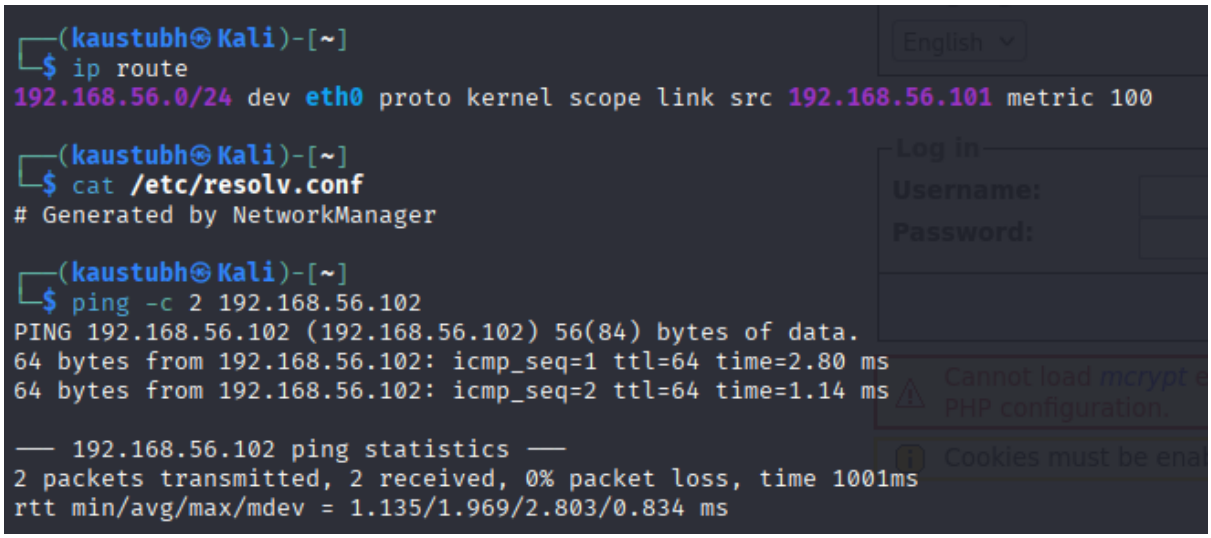


Fig: NFS Export Enumeration

Potential impact: Exporting the filesystem root broadly may expose sensitive files or system information. Whether clients can read or modify files depends on the NFS export options and permissions; the listing alone does not prove those capabilities.

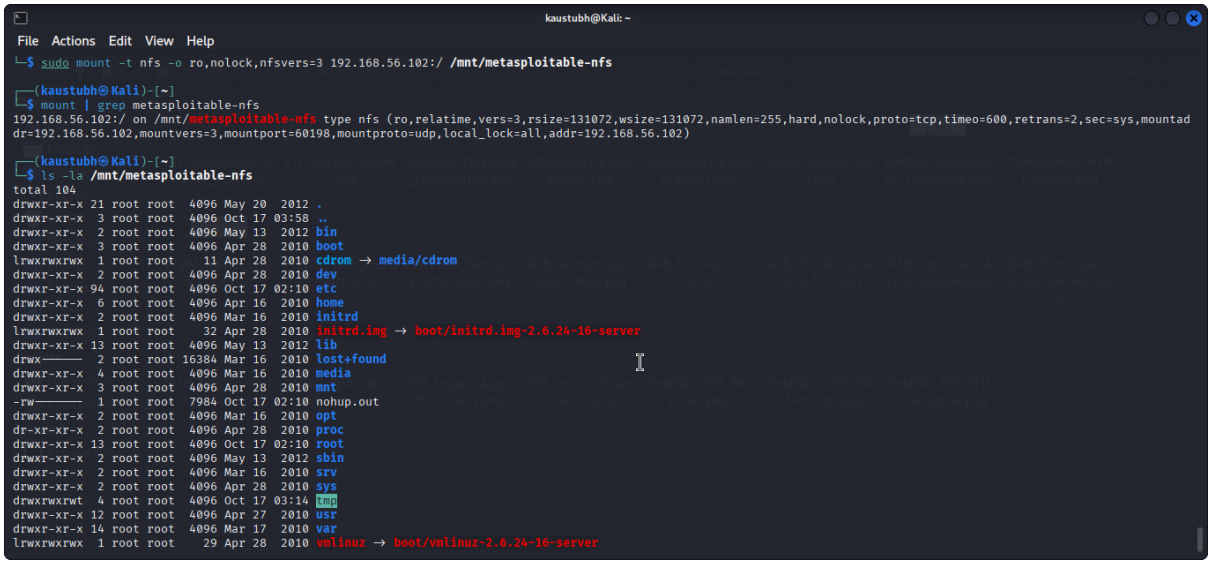


Fig: NFS Root Filesystem ReadOnly Mount

The target advertises its root filesystem as an NFS export accessible to all client addresses according to the export list. During testing, the assessment machine successfully mounted the exported filesystem using NFSv3 with a read-only client mount. The root directory listing exposed entries including `/etc`, `/home`, `/root`, `/tmp`, `/usr`, and `/var`.

Potential impact Depending on server-side export settings and filesystem permissions, this configuration could expose system configuration, application information, user-related files, or other sensitive data to unauthorized network clients.

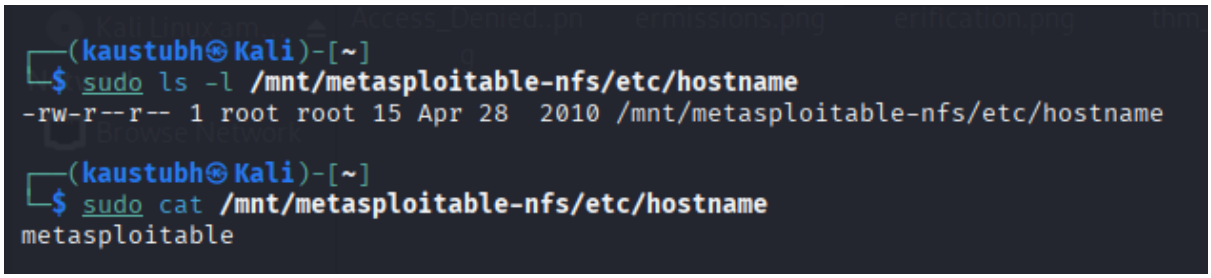


Fig: NFS Hostname File Read

The target advertises its root filesystem as an NFS export available to all client addresses. During testing, Kali Linux successfully mounted the export using NFSv3 and listed its root directory. The assessment also confirmed that `/etc/hostname` could be read through the mount, returning `metasploitable`.

6.5 VULN-03: Anonymous FTP Access

Description: Anonymous login was accepted by the FTP service during an earlier test. The directory listing was empty.

Impact: Anonymous access may expose files if inappropriate permissions are configured.

Severity: Low — preliminary.

Recommendation: Disable anonymous access if it is unnecessary and review file permissions.
Evidence:

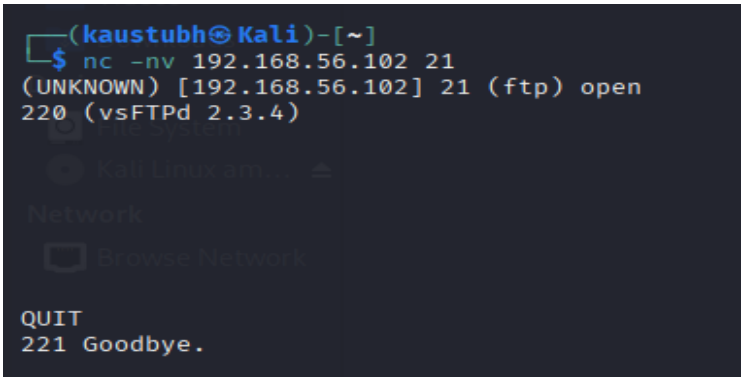


Fig : FTP Service Banner

Important: A version banner is evidence for service identification, not proof of a vulnerability. We will perform further checks before deciding what to report.

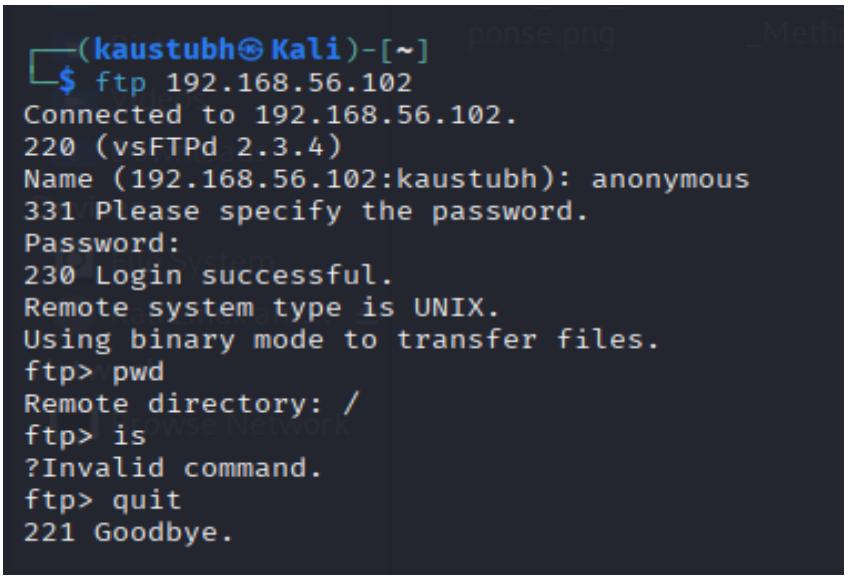


Fig : FTP Anonymous Access Test

6.6 VULN-04: SMB Share Information Exposure

Description: SMB enumeration revealed several share names, and the `tmp` share allowed directory listing during an earlier test.

Impact: Share enumeration may reveal information about the target's resources.

Severity: Low — preliminary.

Recommendation: Restrict share access, review permissions, and disable SMBv1 where it is not required.

Evidence:



6.7 VULN-05: WebDAV Exposure

Description: WebDAV methods were observed on the target's web server during an earlier test.

Impact: Insecure WebDAV configuration may expose web resources to unauthorized access or modification.

Severity: Requires further validation.

Recommendation: Disable WebDAV if unnecessary and restrict access to authorized users. Unauthorized file modification was not confirmed during this assessment.

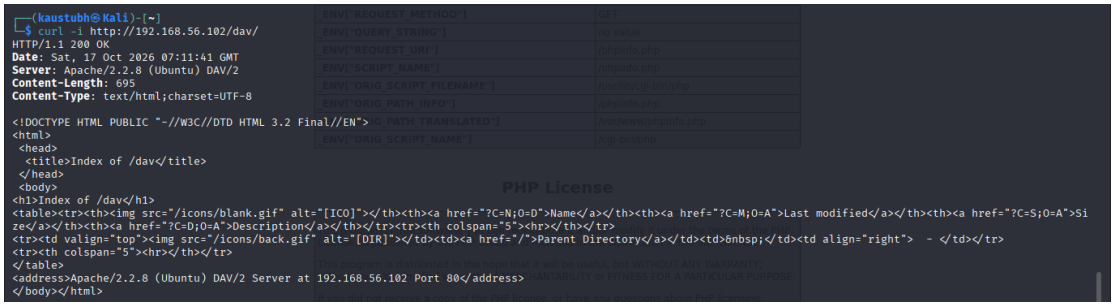


Fig: WebDAV GET Response

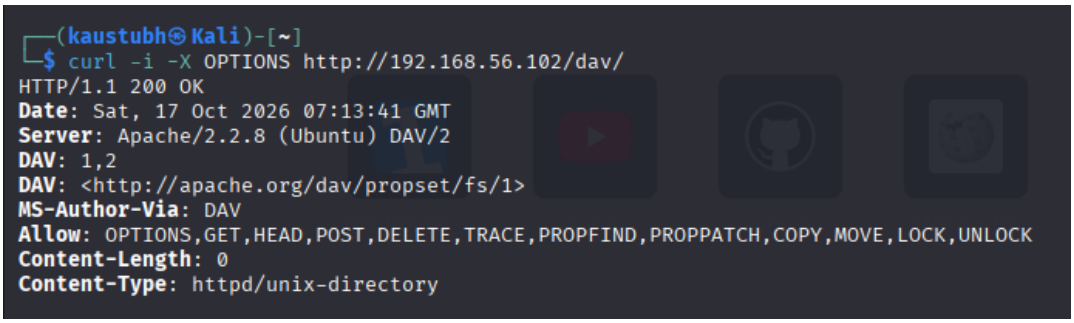


Fig: WebDAV OPTIONS Methods

6.8 VULN-06: Software Version Disclosure

Description: The target disclosed software information, including Apache HTTP Server 2.2.8 and PHP 5.2.4.

Impact: Version information can help identify outdated software requiring security review. The banner alone does not prove a specific vulnerability.

Severity: Informational.

Recommendation: Upgrade unsupported software, disable unnecessary services, and remove excessive version disclosures where appropriate.

7. Exploitation Methodology and Evidence

7.1 Introduction

The exploitation phase was performed to validate the security weaknesses identified during reconnaissance and service enumeration. The assessment focused on determining whether an exposed service could provide unauthorized access to the target machine. All activities were conducted in the authorized, isolated lab environment using Kali Linux and Metasploitable 2 running in Oracle VirtualBox.

7.2 Exploitation Methodology

Step 1: Target Identification

The target machine was identified by its IP address, `192.168.56.103`. Connectivity was checked to confirm that the machine was reachable from Kali Linux before further testing.

Step 2: Port and Service Identification

An Nmap service-version scan was conducted to identify open ports and their associated services.

```
nmap -sV -oN phase2_nmap_scan.txt 192.168.56.103
```

The scan identified several exposed services, including a bindshell service on TCP port `1524`. This service was selected for further validation because it could potentially provide direct command-line access to the target.

Evidence location: `02_Reconnaissance/Nmap_Service_Version_Scan.png`

Step 3: Bindshell Connection

Netcat was used to connect to the exposed service on port 1524.

```
nc -nv -w 3 192.168.56.103 1524
```

The connection successfully provided access to a command shell on the target machine. This demonstrated that the service was accessible from the testing machine without requiring normal user authentication.

Step 4: Privilege Verification

After establishing the shell, the following command was executed to identify the privileges associated with the session.

```
id
```

The command returned the following output:

```
uid=0(root) gid=0(root) groups=0(root)
```

The output confirmed that the shell was operating with root privileges. Root access provides extensive control over a Linux system, including access to system files, configuration settings, and user information. Therefore, an exposed service providing this level of access represents a critical security risk.

Evidence location: `04_Vulnerability_Validation/Bindshell_Root_Access_Proof.png`

Step 5: Evidence Collection

Screenshots were captured to document the service discovery and successful root-access verification. These records provide supporting evidence for the finding and help ensure that the report is based on observed results rather than assumptions.

The evidence was organized into separate folders according to the assessment phase. The screenshots show the relevant commands and their outputs, supporting the findings documented in this report.

7.3 Exploitation Result

The test confirmed that the exposed bindshell service on TCP port 1524 provided root-level shell access to the Metasploitable 2 target machine. The result demonstrates that an attacker with network access to the exposed service could potentially gain complete control of the system.

The relevant screenshots are available in the following project folders:

- **Reconnaissance evidence:** `02_Reconnaissance/Nmap_Service_Version_Scan.png`
- **Root-access verification:** `04_Vulnerability_Validation/Bindshell_Root_Access_Proof.png`

Based on the observed result, the finding was classified as **Critical**. No persistence mechanisms were created, and no data modification or extraction was performed during this validation.

8. Risk Assessment and Impact

8.1 Risk Assessment

The risk assessment evaluates the security weaknesses identified during testing and classifies them according to their potential impact on the target system.

Finding ID	Identified Issue	Risk Level
VULN-01	Unauthenticated root access through bindshell (Port 1524)	Critical
VULN-02	Broad NFS export and filesystem read access	High (Preliminary)
VULN-03	Anonymous FTP access	Low (Preliminary)
VULN-04	SMB service exposure and anonymous share enumeration	Low (Preliminary)
VULN-05	WebDAV enabled on the web server	Further validation required
VULN-06	Outdated software versions	Informational

Note: NFS, FTP, and SMB evidence was collected during an earlier session against `192.168.56.102`. The confirmed bindshell root-access test was performed against `192.168.56.103`.

8.2 Impact Analysis

1. Bindshell — Critical

The exposed service on TCP port 1524 provided root-level shell access without normal authentication. An unauthorized user able to reach this service could potentially gain complete control of the target machine.

2. NFS Exposure — High (Preliminary)

The earlier test demonstrated access to files through a broadly exported NFS filesystem. This could expose sensitive system information. Server-side write access was not verified.

3. Anonymous FTP — Low (Preliminary)

Anonymous FTP login was successful during the earlier session. However, the directory listing was empty, limiting the exposure confirmed by the test.

4. SMB Exposure — Low (Preliminary)

Anonymous share enumeration revealed information about available SMB shares. This could help an attacker understand the system's configuration. Unauthorized file modification was not confirmed.

5. WebDAV — Further Validation Required

WebDAV methods were enabled on the web server. Depending on permissions and configuration, this may create a risk of unauthorized file operations. Successful unauthorized modification was not demonstrated.

6. Outdated Software — Informational

Several legacy software versions were identified during service scanning. Older software may contain known security weaknesses, but the version information alone does not confirm that a specific vulnerability is exploitable.

8.3 Overall Risk

The overall risk is assessed as **Critical** because the bindshell test confirmed root-level access without normal authentication. This weakness could allow complete system compromise if the service were accessible to an unauthorized user.

8.4 Risk Mitigation Recommendations

- Disable the exposed bindshell service and restrict access to TCP port 1524.
- Restrict NFS exports to authorized clients and apply appropriate file permissions.
- Disable anonymous FTP access if it is not required.
- Disable SMBv1 and restrict access to SMB shares.
- Review WebDAV permissions and disable unnecessary methods.
- Upgrade outdated software and operating system components.

9. Remediation Recommendations

Remediation recommendations are provided to address the security weaknesses identified during the assessment of the Metasploitable 2 target machine. The following measures can help reduce security risks and improve system security.

9.1 Disable the Exposed Bindshell Service

Severity: Critical

The bindshell service on TCP port 1524 provided root-level access without normal authentication.

Recommendations:

- Disable and remove the exposed bindshell service.
- Block TCP port 1524 using firewall rules.
- Restrict network access to essential services only.
- Verify that the service is no longer accessible after remediation.

9.2 Secure NFS Configuration

Severity: High (Preliminary)

The NFS assessment demonstrated filesystem read access through a broadly exported filesystem.

Recommendations:

- Restrict NFS exports to trusted client systems.
- Apply appropriate filesystem permissions.
- Enable root squashing where appropriate.
- Disable unnecessary NFS exports.
- Verify access permissions after applying changes.

9.3 Secure FTP Services

Severity: Low (Preliminary)

Anonymous FTP login was successful during the earlier assessment.

Recommendations:

- Disable anonymous FTP access if it is not required.
- Restrict access to authorized users.
- Use secure file-transfer protocols where appropriate.
- Monitor FTP access logs for suspicious activity.

9.4 Improve SMB Security

Severity: Low (Preliminary)

SMB enumeration revealed available shares and service information.

Recommendations:

- Disable SMBv1 and use supported, secure SMB versions.
- Restrict access to authorized users and systems.
- Review share permissions and remove unnecessary shares.
- Disable guest access where it is not required.
- Keep the SMB service updated.

9.5 Secure WebDAV Configuration

Severity: Further validation required

WebDAV methods were detected on the web server.

Recommendations:

- Disable WebDAV if it is unnecessary.
- Restrict write operations to authorized users.
- Review enabled HTTP methods and disable unnecessary ones.
- Apply authentication and access controls.
- Test permissions to confirm that unauthorized file operations are prevented.

9.6 Update Outdated Software

Severity: Informational

Several legacy software versions were identified during service enumeration.

Recommendations:

- Upgrade outdated software to supported versions.
- Apply available security patches.
- Remove unnecessary or unused services.
- Perform regular vulnerability assessments.
- Review service configurations after updates.

9.7 General Security Improvements

The following security measures are recommended to improve the overall security of the system:

- Configure a firewall to allow only required ports.
- Follow the principle of least privilege.
- Disable unnecessary services and default accounts.
- Monitor system and authentication logs.
- Perform regular security updates and vulnerability scans.

10. Conclusion and Lessons Learned

10.1 Conclusion

The Vulnerability Assessment and Penetration Testing (VAPT) exercise was conducted on the Metasploitable 2 virtual machine using Kali Linux and Oracle VirtualBox. The assessment included network configuration, connectivity testing, port scanning, service enumeration, vulnerability validation, and risk assessment.

During the assessment, multiple exposed services were identified, including FTP, SSH, SMB, HTTP, NFS, and other network services. The most significant finding was the exposed bindshell service on TCP port 1524, which provided root-level shell access without normal authentication. This finding was classified as Critical because it could allow complete system compromise if accessible to an unauthorized user.

The assessment also identified security concerns involving NFS exposure, anonymous FTP access, SMB enumeration, WebDAV configuration, and outdated software versions. Remediation recommendations were provided to address these issues and improve the security of the target system. Overall, this practical exercise demonstrated the importance of identifying exposed services, validating security weaknesses, documenting evidence, and applying appropriate security controls.

10.2 Lessons Learned

The following lessons were learned during this practical assessment:

1. **Virtual Lab Setup:** Learned to configure Kali Linux and Metasploitable 2 in Oracle VirtualBox for controlled security testing.
2. **Network Reconnaissance:** Gained practical experience checking connectivity and identifying active network services.
3. **Port Scanning:** Learned to use Nmap to discover open ports and identify running service versions.
4. **Service Enumeration:** Understood how exposed services such as FTP, SMB, NFS, and WebDAV can reveal useful information about a target system.

5. **Vulnerability Validation:** Learned to validate security findings using practical tests and command-line tools.
6. **Privilege Verification:** Understood the significance of root-level access and its potential impact on system security.
7. **Risk Assessment:** Learned to classify findings according to their severity and potential impact.
8. **Evidence Documentation:** Gained experience recording commands, outputs, screenshots, and results for a professional VAPT report.
9. **Remediation Planning:** Learned how disabling unnecessary services, restricting network access, applying updates, and enforcing least privilege can reduce security risks.
10. **Ethical Testing:** Understood the importance of performing penetration testing only in authorized environments and avoiding unnecessary changes to the target system.

10.3 Final Outcome

The project provided practical experience in conducting a basic VAPT assessment within a controlled virtual lab. It strengthened understanding of network security, service enumeration, vulnerability validation, risk classification, and remediation planning. These skills provide a foundation for further learning in ethical hacking and cybersecurity.